정보보안

차례

항목을 누르면 해당 장으로 이동합니다. PDF 책갈피에서도 과목을 찾을 수 있습니다.

정보보안 · 30분 학습 방법 6

정보보안 001회차 | 06-01 원리 I 7

정보보안 002회차 | 06-01 원리II 8

정보보안 003회차 | 06-01 예제·적용 9

정보보안 004회차 | 06-01 직접 문제 10

정보보안 005회차 | 06-01 해설·재현 12

정보보안 006회차 | 06-01 원리 I 13

정보보안 007회차 | 06-01 원리II 14

정보보안 008회차 | 06-01 예제·적용 15

정보보안 009회차 | 06-01 직접 문제 16

정보보안 010회차 | 06-01 해설·재현 18

정보보안 011회차 | 06-02 원리 I 20

정보보안 012회차 | 06-02 원리II 21

정보보안 013회차 | 06-02 예제·적용 22

정보보안 014회차 | 06-02 직접 문제 23

정보보안 015회차 | 06-02 해설·재현 25

정보보안 016회차 | 06-02 원리 I 26

정보보안 017회차 | 06-02 원리II 27

정보보안 018회차 | 06-02 예제·적용 28

정보보안 019회차 | 06-02 직접 문제 29

정보보안 020회차 | 06-02 해설·재현 31

정보보안 021회차 | 06-03 원리 I 33

정보보안 022회차 | 06-03 원리II 34

정보보안 023회차 | 06-03 예제·적용 35

정보보안 024회차 | 06-03 직접 문제 36

정보보안 025회차 | 06-03 해설·재현 38

정보보안 026회차 | 06-03 원리 I 39

정보보안 027회차 | 06-03 원리II 40

정보보안 028회차 | 06-03 예제·적용 41

정보보안 029회차 | 06-03 직접 문제 42

정보보안 030회차 | 06-03 해설·재현 44

정보보안 031회차 | 06-04 원리 I 46

정보보안 032회차 | 06-04 원리II 47

정보보안 033회차 | 06-04 예제·적용 48

정보보안 034회차 | 06-04 직접 문제 49

정보보안 035회차 | 06-04 해설·재현 51

정보보안 036회차 | 06-04 원리 I 52

정보보안 037회차 | 06-04 원리II 53

정보보안 038회차 | 06-04 예제·적용 54

정보보안 039회차 | 06-04 직접 문제 55

정보보안 040회차 | 06-04 해설·재현 57

정보보안 041회차 | 06-05 원리 I 59

정보보안 042회차 | 06-05 원리II 60

정보보안 043회차 | 06-05 예제·적용 61

정보보안 044회차 | 06-05 직접 문제 62

정보보안 045회차 | 06-05 해설·재현 64

정보보안 046회차 | 06-05 원리 I 65

정보보안 047회차 | 06-05 원리II 66

정보보안 048회차 | 06-05 예제·적용 67

정보보안 049회차 | 06-05 직접 문제 68

정보보안 050회차 | 06-05 해설·재현 70

정보보안 051회차 | 06-06 원리 I 72

정보보안 052회차 | 06-06 원리II 73

정보보안 053회차 | 06-06 예제·적용 74

정보보안 054회차 | 06-06 직접 문제 75

정보보안 055회차 | 06-06 해설·재현 77

정보보안 056회차 | 06-06 원리 I 78

정보보안 057회차 | 06-06 원리II 79

정보보안 058회차 | 06-06 예제·적용 80

정보보안 059회차 | 06-06 직접 문제 81

정보보안 060회차 | 06-06 해설·재현 83

정보보안 061회차 | 06-07 원리 I 85

정보보안 062회차 | 06-07 원리II 86

정보보안 063회차 | 06-07 예제·적용 87

정보보안 064회차 | 06-07 직접 문제 88

정보보안 065회차 | 06-07 해설·재현 90

정보보안 066회차 | 06-07 원리 I 91

정보보안 067회차 | 06-07 원리II 92

정보보안 068회차 | 06-07 예제·적용 93

정보보안 069회차 | 06-07 직접 문제 94

정보보안 070회차 | 06-07 해설·재현 96

정보보안 071회차 | 06-08 원리 I 98

정보보안 072회차 | 06-08 원리II 99

정보보안 073회차 | 06-08 예제·적용 100

정보보안 074회차 | 06-08 직접 문제 101

정보보안 075회차 | 06-08 해설·재현 103

정보보안 076회차 | 06-08 원리 I 104

정보보안 077회차 | 06-08 원리II 105

정보보안 078회차 | 06-08 예제·적용 106

정보보안 079회차 | 06-08 직접 문제 107

정보보안 080회차 | 06-08 해설·재현 109

근거·범위·검증 상태 111

30분 학습 방법

30분 안에서 진행하기

복습 3분 → 학습 25분 → 기록 2분으로 진행합니다. 시간이 끝나면 멈추고, 남은 범위는 다음 학습일에 같은 회차에서 이어갑니다. 한 회차를 하루에 반드시 끝내야 하는 것은 아닙니다.

원리 → 문제 → 분리 해설

각 5회차 묶음에서 앞 3회차는 원리와 예제를 읽고, 4회차는 직접 문제를 풀며, 5회차는 해설을 비교하고 답 없이 다시 풉니다. 완료 기준은 읽은 쪽수보다 용어·조건을 설명하고 풀이를 재현할 수 있는지입니다.

강조와 보완 자료 활용

노란색으로 표시한 핵심 조건을 먼저 확인한 뒤, 예제에서 그 조건이 어떻게 쓰였는지 설명합니다. 책 뒤 112쪽부터는 반례·손풀이·추가 확인 문제가 있습니다. 해당 주제가 어려운 날의 학습 시간 안에 골라 읽습니다. 추가 문제의 해설은 별도 절에 있습니다.

공부 기록은 한 곳에

Obsidian의 「공부기록」에 과목·회차·실제 공부 시간·다음 시작점을 남깁니다. 「하루공부」 템플릿을 같은 기록에 추가해서 사용합니다. PDF의 강조나 필기는 진도 표를 자동으로 변경하지 않습니다.

정보보안 001회차 | 06-01 원리 I

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 1/80회차 · 기록 묶음 01의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

학습 목표

정보보안은 특정 공격 이름만 외우는 과목이 아니다. 무엇을 지키는지, 어떤 조건에서 침해되는지, 어떤 통제가 효과가 있는지를 연결한다. 이 과목은 기보 전산과 IBK IT의 공식 안내에 명시되어 있다. 보안 실무의 최신 수치·제품·법 조문을 암기 자료로 고정하지 않고, 비교적 안정적인 원리와 시험 용어를 먼저 익힌다.

CIA와 추가 속성

기밀성은 허가받지 않은 공개를 막는 것이다. 무결성은 허가되지 않은 변경·훼손을 방지하거나 탐지하는 성질이다. 가용성은 권한 있는 사용자가 필요할 때 서비스를 사용할 수 있는 성질이다. 고객 정보가 유출되면 기밀성, 계좌 금액이 변조되면 무결성, 서비스가 중단되면 가용성과 직접 관련된다. 하나의 사건이 여러 속성을 동시에 해칠 수 있다.

인증은 누가 요청했는지 확인하는 과정이다. 부인방지는 행위자가 자신의 행위를 나중에 부인하기 어렵게 만드는 특성과 관련된다. 추적성·책임성은 누가 무엇을 했는지 설명할 수 있는 운영 기록과 통제에 연결된다. 로그를 많이 남긴다고 모든 행위의 법적 부인방지가 자동으로 완성되는 것은 아니다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 002회차 | 06-01 원리ㅍ

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 2/80회차 · 기록 묶음 01의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

위험을 구성하는 용어

자산은 보호해야 할 데이터·시스템·서비스·평판 등이다. 위협은 자산을 해칠 수 있는 사건이나 원인이다. 취약점은 위협이 활용할 수 있는 약점이다. 위험은 발생 가능성과 영향이 결합된 불확실성이다. 직원 퇴사 뒤 계정이 살아 있는 것은 취약점, 해당 계정의 오용은 위협 시나리오, 고객 자료는 자산으로 구분할 수 있다.

통제는 예방·탐지·교정 등의 관점으로 분류한다. 최소권한과 입력 검증은 예방, 경보와 감사 로그는 탐지, 복구·패치·계정 차단은 교정에 기여한다. 한 통제는 여러 역할을 할 수 있다. 다층 방어는 서로 다른 통제로 한 가지 실패의 영향을 줄이려는 접근이다.

정량 위험 예제

가상 데이터 유출 사고의 손실 규모를 2,000만원, 1년 발생 확률을 0.1로 추정하면 단순 기대 손실은 200만원/년이다. 80만원/년의 통제를 적용했을 때 확률이 0.03으로 내려간다면 잔여 기대 손실은 60만원/년, 통제 비용 포함 값은 140만원/년이다. 단순 모형에서는 60만원의 개선이 있다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 003회차 | 06-01 예제·적용

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 3/80회차 · 기록 묶음 01의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

이 계산은 확률·손실 추정이 맞다는 가정 아래의 예제다. 큰 꼬리 위험, 규제 의무, 복구 불가능한 신뢰 손상은 평균값만으로 결정하지 않는다. 고전적 계산 문제에서 SLE=자산가치×노출계수, ALE=SLE×연간발생률을 쓰면 연간발생률은 반드시 확률과 같은 개념은 아니다. 한 해 여러 번 발생할 수 있는 사건에서는 발생 횟수의 기대값으로 줄 수도 있다.

개발 경력과 연결

검사 장비에서 레시피 파일이 변조되면 불량 판정이 달라질 수 있으므로 무결성이 중요하다. 이미지에 고객 공정 정보가 들어 있다면 기밀성이 중요하다. 검사 프로그램이 멈추면 생산 차질로 가용성이 중요하다. "사내 장비니까 보안은 로그인 하나면 된다"는 판단은 세 목표를 모두 고려하지 않은 것이다.

자가 연습과 풀이

백업은 어느 목표를 도울까? 복구를 통해 가용성을 돕고, 신뢰할 수 있는 이전 상태로 무결성 회복을 도울 수 있다. 백업 자체가 유출되면 기밀성 위험을 추가한다. 따라서 암호화·접근통제·분리 보관·복구 시험이 함께 필요하다.

완료 기준

하나의 보안 사고에서 자산·위협·취약점·통제·잔여 위험을 각각 한 문장으로 설명하고, CIA 중 어느 속성이 직접 영향을 받는지 근거를 쓸 수 있어야 한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 004회차 | 06-01 직접 문제

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 4/80회차 · 기록 묶음 01의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q01

고객 계좌 금액이 권한 없이 바뀐 사건과 가장 직접 관련된 보안 속성은?

1. 기밀성만

2. 무결성

3. 전송 속도

4. 코드 응집도

내 선택·근거: _____

B06Q02

퇴사자의 계정이 비활성화되지 않은 상태를 가장 직접적으로 분류하면?

1. 자산 가치

2. 취약점

3. 완전한 예방 통제

4. 전자서명

내 선택·근거: _____

B06Q03

손실 2,000만원, 연간 발생 확률 0.1이라는 단순 모형의 기대 손실은?

1. 20만원

2. 100만원

3. 2,000만원

4. 200만원

내 선택·근거: _____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 005회차 | 06-01 해설·재현

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 5/80회차 · 기록 묶음 01의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

먼저 직접 푼 뒤 확인합니다.

B06Q01

정답: 2번

허가되지 않은 데이터 변경은 무결성 문제다. 유출은 기밀성, 중단은 가용성에 직접 연결되며 속도·응집도는 이 사건의 보안 목표가 아니다.

B06Q02

정답: 2번

오용될 수 있는 권한·계정 상태의 약점이 취약점이다. 고객 정보는 자산, 해당 계정 오용은 위협 시나리오로 구분한다.

B06Q03

정답: 4번

2,000×0.1=200만원/년이다. 이 계산은 주어진 확률·손실 가정에 한정되며 손실 전체가 사라진다는 뜻이 아니다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 006회차 | 06-01 원리 I

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 6/80회차 · 기록 묶음 02의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

응용 문제: 통제의 효과와 잔여 위험

관리자 권한을 줄이고 MFA를 적용해도 모든 위험이 없어지지는 않는다. 애플리케이션의 권한 검사 누락, 이미 열린 세션, 복구 계정, 내부 오용 같은 별도 경로가 남을 수 있다. 통제가 어떤 공격 조건을 끊는지 설명하고 남는 경로를 찾는 것이 중요하다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 007회차 | 06-01 원리ㅍ

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 7/80회차 · 기록 묶음 02의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

가상 통제 A는 사고 확률을 낮추고 B는 사고 때 복구 시간을 줄인다. 둘 다 유용하지만 예방과 피해 완화의 주된 효과가 다르다. 위험을 '위협 수×취약점 수'로 단순히 정수 곱한다고 보편적인 객관 수치가 생기는 것은 아니다. 정성 평가도 척도·평가 기준·근거를 기록해야 비교할 수 있다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 008회차 | 06-01 예제·적용

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 8/80회차 · 기록 묶음 02의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

강화 손풀이: 연간 발생률과 통제의 순편익

가상 자산가치 1,000만원, 사고당 노출계수 0.2, 연간 기대 발생횟수 0.4회다. 손실·통제비용을 같은 연간 기준으로 비교한다.

1. 사고 한 번의 손실 SLE=1,000×0.2=200만원이다.

2. ALE=200×0.4=80만원/년이다. 0.4회는 기대 횟수이며 적어도 한 번 발생할 확률이라고 단정하지 않는다.

3. 통제 A는 연 35만원, 적용 뒤 발생률 0.1회다. 잔여 손실 20만원+통제 35만원=55만원/년, 순 개선 25만원이다.

4. 통제 B는 연 10만원, 적용 뒤 0.3회다. 합계 60+10=70만원/년으로 A보다 낮은 비용만 보고 B를 선택할 수 없다.

이 가상 목표가 비용 합 최소화라면 A가 유리하지만 실제 규제 의무·치명적 손실·확률 추정 오차는 이 평균값에 전부 들어 있지 않다. 예방 통제로 가능성을 줄이고 탐지·복구 통제로 사건의 범위와 지속시간을 줄일 수 있다. '보험에 가입했으므로 취약점을 방치해도 된다'는 반례는 위험 전가와 안전한 운영을 혼동한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 009회차 | 06-01 직접 문제

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 9/80회차 · 기록 묶음 02의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이·서술형 작성
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개와 서술형 1개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q25

가상 자산 1,000만원·사고당 노출계수 0.2·연간 기대 발생 0.4회이다. SLE와 ALE는?

1. 200만원·80만원/년

2. 200만원·400만원/년

3. 80만원·200만원/년

4. 1,000만원·400만원/년

내 선택·근거: _____

B06Q26

사고당 손실 200만원이다. 통제 A는 연간 비용 35만원·잔여 기대 0.1회/년, B는 10만원·0.3회/년이다. 통제 비용+잔여 기대 손실 최소 목표의 선택과 A 합계는?

1. B·10만원/년

2. A·55만원/년

3. B·70만원/년

4. A·20만원/년

내 선택·근거: _____

B06Q27

연간 기대 발생 횟수가 0.4회라는 정보만으로 확정할 수 없는 것은? 사고당 손실은 항상 200만원이라고 가정한다.

1. 연간 기대 손실이 80만원

2. 연간 발생률의 단위가 회/년임

3. 사건 횟수의 기대값이 0.4회

4. 그해 적어도 한 번 발생할 확률이 40%라는 결론

내 선택·근거: _____

W06Q01

자산 1,000만원·노출계수 0.2·연간 기대 0.4회이다. 통제 A는 연 35만원·잔여 0.1회, B는 연 10만원·잔여 0.3회다. SLE·ALE·통제별 비용 합과 모형의 한계를 설명하라.

조건·원리·중간 과정·결론 순서로 먼저 답안을 작성합니다.

내 답안: _____

_____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 010회차 | 06-01 해설·재현

보안 목표와 위험: 자산·위협·취약점을 분리하기 · 과목 10/80회차 · 기록 묶음 02의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

서술형 모범답안과 자가 채점 기준

B06Q25

정답: 1번

정답 근거: SLE=1,000×0.2=200만원, ALE=200×0.4=80만원/년이다.

「200만원·400만원/년」 - 자산에 발생률을 직접 곱해 노출계수를 빠뜨렸다.

「80만원·200만원/년」 - 사고 한 번의 손실과 연간 기대 손실을 뒤집었다.

「1,000만원·400만원/년」 - 사고당 노출계수를 누락했다.

B06Q26

정답: 2번

정답 근거: A=200×0.1+35=55, B=200×0.3+10=70으로 A가 작다.

「B·70만원/년」 - B 합계 70은 맞지만 A 합계 55보다 크다.

「A·20만원/년」 - A의 잔여 손실 20만 세고 통제 비용 35를 빠뜨렸다.

「B·10만원/년」 - B의 통제 비용만 세고 잔여 손실 60을 빠뜨렸다.

B06Q27

정답: 4번

정답 근거: 기대 횟수와 한 번 이상 발생 확률은 분포 조건 없이 같다고 할 수 없다.

「사건 횟수의 기대값이 0.4회」 - 주어진 기대 발생 횟수의 정의 그대로다.

「연간 기대 손실이 80만원」 - 손실이 사건 횟수×200이므로 기대값은 0.4×200=80이다.

「연간 발생률의 단위가 회/년임」 - 연간 횟수의 단위는 회/년이다.

W06Q01

자산 1,000만원·노출계수 0.2·연간 기대 0.4회이다. 통제 A는 연 35만원·잔여 0.1회, B는 연 10만원·잔여 0.3회다. SLE·ALE·통제별 비용 합과 모형의 한계를 설명하라.

모범답안

SLE=1,000×0.2=200만원, ALE=200×0.4=80만원/년이다. A는 잔여 20+비용 35=55, B는 잔여 60+비용 10=70만원/년이다. 통제 비용과 잔여 기대 손실의 합만 최소화하는 목표에서는 A가 낫다. 기대 횟수 0.4와 한 번 이상 사고 확률은 자동으로 같지 않다. 실제 의무·극단 손실·추정 오차는 이 단순 비용 모형 밖에서도 검토한다.

10점 자가 채점 기준

- 3점: SLE 식과 200만원 1점, ALE 식과 80만원/년 2점을 계산한다.
- 4점: A55·B70의 비용 합 각각 1점, A 선택 1점, 비용 합 최소라는 목표 조건 1점을 쓴다.
- 3점: 기대 횟수와 발생 확률의 차이 1점, 극단 손실·의무·추정 오차 등 모형 밖 조건 두 가지 각각 1점을 설명한다.

점수는 학습용 자가 채점이며 실제 시험 배점 재현이 아닙니다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 011회차 | 06-02 원리 I

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 11/80회차 · 기록 묶음 03의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

인증과 인가

인증(AuthN)은 주장한 신원을 확인한다. 인가(AuthZ)는 확인된 주체가 어떤 자원에 어떤 행동을 할 수 있는지 결정한다. 로그인 성공은 모든 신청서에 접근할 권리가 있다는 뜻이 아니다. 서버는 요청마다 적절한 권한과 대상 객체의 관계를 확인해야 한다. 화면에서 버튼을 숨겨도 API 권한 검사가 빠지면 통제가 완성되지 않는다.

인증 요소는 알고 있는 것, 가지고 있는 것, 신체적 특성 등으로 구분한다. 비밀번호와 PIN은 둘 다 지식 요소라서 개수가 두 개라는 이유만으로 서로 다른 요소의 다중요소 인증이 되지는 않는다. 소유 요소의 보안도 피싱·기기 탈취·복구 경로에 영향을 받는다.

접근통제 모델

DAC는 자원 소유자 등이 권한을 재량적으로 설정하는 모델이다. MAC는 보안등급·레이블과 중앙 정책에 따른 강제 접근통제를 설명한다. RBAC는 역할에 권한을 부여하고 사용자에게 역할을 할당한다. ABAC는 사용자·자원·행동·환경 속성과 정책을 함께 평가한다. 조직에서 여러 모델을 결합할 수 있다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 012회차 | 06-02 원리ㅍ

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 12/80회차 · 기록 묶음 03의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

최소권한은 업무에 필요한 권한만 부여하는 원칙이다. 직무 분리는 중요한 작업의 승인과 집행을 한 사람이 단독으로 모두 수행하지 못하게 하는 통제다. 최소권한이 권한을 영구히 줄이기만 한다는 뜻은 아니다. 필요한 시간에 제한된 권한을 부여하고 종료 뒤 회수하는 방법도 있다. 기본 거부와 명시적 허용은 실수로 접근을 허용하는 위험을 줄인다.

고전적 기밀성·무결성 모델

Bell-LaPadula는 기밀성을 중심으로 설명한다. 기초 규칙은 낮은 등급이 높은 등급을 읽지 못하는 no read up, 높은 등급의 주체가 낮은 등급으로 쓰지 못하는 no write down이다. Biba의 대표적인 엄격 무결성 규칙은 낮은 신뢰도의 데이터를 읽어 오염되지 않도록 하는 no read down, 낮은 무결성 주체가 높은 무결성 대상에 쓰지 못하는 no write up이다.

이 규칙은 해당 모델과 기본 가정 안에서 해석한다. 두 모델의 "높다"는 기밀 등급인지 무결성 신뢰 수준인지 다르다. 모델 이름만 바꾸어 같은 화살표를 적용하지 않는다.

단계별 사례: 신청서 조회 API

사용자 17이 신청서 902를 조회한다. 서버는 먼저 세션의 사용자 17을 인증한다. 다음으로 신청서 902의 소유자가 17인지 또는 적절한 심사 역할에 속하는지 확인한다. 신청서 번호가 추측하기 어렵게 생겼어도 권한 검사가 빠지면 객체 단위 권한 취약점이 된다. 입력 값을 난수처럼 바꾸는 것은 보조 방편이고 권한 결정의 대체가 아니다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 013회차 | 06-02 예제·적용

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 13/80회차 · 기록 묶음 03의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

역할이 신청자·심사자·관리자라면 단순한 업무 권한은 RBAC로 표현할 수 있다. "심사자이면서 담당 지역이 같고 근무 시간이며 관리 기기에서 접속" 같은 조건은 ABAC 관점이 더 직접적이다. 권한 부여·변경·회수 기록도 확인한다.

숫자 예제와 연습

총 사용자 120명 중 12명만 배포 권한이 필요하다. 전원에게 권한을 주었다가 최소권한 원칙으로 12명에만 남기면 배포 권한 보유자는 108명 감소하고 90% 감소한다. 이 수치는 권한 범위 감소를 나타낼 뿐 사고 확률이 곧바로 90% 줄어든다는 뜻은 아니다.

자가 연습: 관리자가 휴직했는데 관리자 권한이 유지된다면 무엇을 확인할까? 현재 업무 필요, 권한 승인·회수 절차, 비상 계정과 일반 계정 분리, 실제 사용 기록을 확인한다.

완료 기준

인증·인가를 API 처리 순서로 설명하고, DAC·MAC·RBAC·ABAC를 사례로 구분하며, Bell-LaPadula와 Biba의 읽기·쓰기 방향을 혼동하지 않아야 한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 014회차 | 06-02 직접 문제

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 14/80회차 · 기록 묶음 03의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q04

로그인 성공 후 다른 사람의 신청서 조회를 거절하는 검사는 주로 무엇인가?

1. 인가

2. 압축

3. 백업

4. 키 공간 확장

내 선택·근거: _____

B06Q05

비밀번호와 별도 PIN을 함께 요구하는 상황에 대한 정확한 설명은?

1. 항상 소유+생체 MFA다.

2. 둘 모두 지식 요소이므로 서로 다른 요소의 MFA라고 자동 분류할 수 없다.

3. 암호가 두 개면 무조건 공개키 인증이다.

4. PIN은 무결성 등급이다.

내 선택·근거: _____

B06Q06

Bell-LaPadula의 기밀성 기본 규칙으로 옳은 조합은?

1. no read down, no write up

2. 모든 읽기와 쓰기 허용

3. 읽기만 인증 없이 허용

4. no read up, no write down

내 선택·근거: _____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 015회차 | 06-02 해설·재현

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 15/80회차 · 기록 묶음 03의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

먼저 직접 푼 뒤 확인합니다.

B06Q04

정답: 1번

신원 확인은 인증, 자원에 대한 행동 허용 여부는 인가다. 인증 성공만으로 타인의 신청서를 읽을 권한은 생기지 않는다.

B06Q05

정답: 2번

인증 요소의 개수보다 종류가 중요하다. 두 값은 모두 알고 있는 것에 해당하며 소유·생체·공개키·등급과는 다르다.

B06Q06

정답: 4번

기밀 정보가 낮은 등급으로 흘러가지 않도록 no read up과 no write down을 설명한다. no read down/no write up은 대표적 엄격 Biba 무결성 규칙과 연결된다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 016회차 | 06-02 원리 I

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 16/80회차 · 기록 묶음 04의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

응용 문제: 역할과 객체 소유권의 결합

신청자 역할이 있다는 이유만으로 모든 신청서 조회를 허용하면 RBAC 설정 자체와 별개로 객체 권한 문제가 생긴다. 먼저 기능 권한을 확인하고, 다음으로 대상 신청서와 요청자의 관계를 확인한다. 심사자라면 담당 범위와 상태 조건도 필요할 수 있다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 017회차 | 06-02 원리ㅍ

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 17/80회차 · 기록 묶음 04의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

Bell-LaPadula에서 비밀 등급 주체가 더 낮은 등급 파일에 비밀 내용을 쓰면 no write down에 위배될 수 있다. Biba에서 낮은 신뢰의 주체가 높은 무결성 자료를 수정하면 no write up에 위배될 수 있다. 같은 높음/낮음 표시라도 보호 목적이 다르므로 모델 이름과 등급 의미를 먼저 고정한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 018회차 | 06-02 예제·적용

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 18/80회차 · 기록 묶음 04의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

강화 권한 행렬: 역할·객체·행위의 AND 조건

가상 역할은 조회자·승인자·감사자 중 하나다. 읽기는 (조회자 AND 같은 지역) OR 감사자, 승인은 승인자 AND 같은 지역 AND 요청 작성자가 자신 아님일 때만 허용한다. 다른 경우는 거절한다. 이 규칙은 실제 기관 정책이 아니다.

손풀이: 조회자 민수가 부산 자료를 보되 소속은 경기라면 읽기는 거절이다. 감사자는 지역이 달라도 읽지만 승인 권한은 없다. 부산 승인자 지수가 부산 요청을 처리하더라도 본인이 작성한 요청이면 승인은 거절이다. 로그인 성공은 이 행위 권한을 대신하지 않는다.

서버에서 매 요청의 사용자·대상 객체·행위·현재 권한을 검사한다. 화면에 버튼을 숨겼어도 API를 직접 호출하면 같은 검사가 필요하다. 권한이 철회됐는데 오래된 화면·토큰의 역할만 믿는 반례를 시험한다. 서버의 정책 결정과 거절 결과를 로그에 적절히 남기되 비밀값을 그대로 기록하지 않는다. 최소 권한은 한 번 권한을 작게 준 뒤 끝나는 작업이 아니라 변경·철회·만료도 다루는 원리다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 019회차 | 06-02 직접 문제

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 19/80회차 · 기록 묶음 04의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이·서술형 작성
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개와 서술형 1개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q28

가상 역할은 조회자·승인자·감사자 중 하나뿐이다. 읽기는 (조회자 AND 같은 지역) OR 감사자일 때만 허용한다. 경기 조회자의 부산 자료 읽기 판정은?

1. 조회자이므로 항상 허용

2. 로그인됐으면 허용

3. 거절

4. 파일명이 공개면 허용

내 선택·근거: _____

B06Q29

가상 승인 조건은 승인자 AND 같은 지역 AND 요청 작성자와 다른 사람이다. 같은 지역 승인자가 본인 요청을 승인하려 한다. 판정은?

1. 거절

2. 두 조건 통과하므로 허용

3. 감사 로그만 남기면 허용

4. 화면 버튼이 보이면 허용

내 선택·근거: _____

B06Q30

권한 철회 뒤 옛 화면의 승인 버튼이 남아 있다. 가상 규약은 서버가 매 요청의 현재 권한을 검사한다. 올바른 처리는?

1. 객체 ID가 숫자이면 허용

2. 직접 API 호출도 현재 권한에 따라 거절

3. 옛 화면 상태로 허용

4. 버튼이 보이면 철회가 취소됨

내 선택·근거: _____

W06Q02

가상 승인은 승인자 AND 같은 지역 AND 요청 작성자와 다른 사람일 때만 가능하다. 로그인된 같은 지역 승인자가 본인 요청을 처리할 때 판정과 시험을 설명하라.

조건·원리·중간 과정·결론 순서로 먼저 답안을 작성합니다.

내 답안: _____

_____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 020회차 | 06-02 해설·재현

인증·인가·접근통제: 로그인 뒤에도 권한을 검사하기 · 과목 20/80회차 · 기록 묶음 04의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

서술형 모범답안과 자가 채점 기준

B06Q28

정답: 3번

정답 근거: 다른 지역이므로 첫 조건이 거짓이고 감사자도 아니어서 거절한다.

「조회자이므로 항상 허용」 - 조회자에게는 같은 지역 조건도 필요하다.

「로그인됐으면 허용」 - 인증 성공은 자료 접근의 인가 조건을 대신하지 않는다.

「파일명이 공개면 허용」 - 파일명 공개에 관한 예외가 규약에 없다.

B06Q29

정답: 1번

정답 근거: 필수 세 조건 중 작성자 분리가 거짓이다.

「두 조건 통과하므로 허용」 - 세 조건 모두 참이어야 하므로 두 조건만으로 부족하다.

「감사 로그만 남기면 허용」 - 로그 기록은 승인 금지의 예외로 주어지지 않았다.

「화면 버튼이 보이면 허용」 - 화면 상태는 서버의 승인 규칙을 대신하지 않는다.

B06Q30

정답: 2번

정답 근거: 현재 권한 검사를 적용하므로 철회된 승인 행위를 거절한다.

「옛 화면 상태로 허용」 - 현재 권한 검사 규약을 위반한다.

「버튼이 보이면 철회가 취소됨」 - 화면이 서버 권한 정책을 자동 변경하지 않는다.

「객체 ID가 숫자이면 허용」 - ID의 자료형과 행위 권한은 서로 다른 조건이다.

W06Q02

가상 승인은 승인자 AND 같은 지역 AND 요청 작성자와 다른 사람일 때만 가능하다. 로그인된 같은 지역 승인자가 본인 요청을 처리할 때 판정과 시험을 설명하라.

모범답안

작성자 분리 조건이 거짓이므로 거절한다. 로그인은 신원을 확인하지만 승인 조건은 서버가 현재 사용자·역할·지역·객체 작성자를 확인해야 한다. 정상적인 타인 요청은 허용하고 자기 요청·다른 지역 요청·권한 철회 뒤 직접 API 호출은 거절하는 시험을 작성한다.

10점 자가 채점 기준

- 3점: 세 AND 조건을 1점, 자기 승인 거절과 그 조건을 2점으로 설명한다.
- 3점: 인증과 인가 구분 1점, 서버의 현재 역할·객체 조건 검사 2점을 쓴다.
- 4점: 정상 타인 요청 1점, 거절 사례 두 가지 각각 1점, 직접 API 경계 확인 1점을 제시한다.

점수는 학습용 자가 채점이며 실제 시험 배점 재현이 아닙니다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 021회차 | 06-03 원리 I

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 21/80회차 · 기록 묶음 05의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

대칭키와 공개키

대칭키 암호는 암호화와 복호화에 같은 비밀키 또는 쉽게 연관되는 비밀키를 사용한다. 많은 데이터를 효율적으로 보호할 때 사용하지만 키를 안전하게 공유하는 문제가 있다. 공개키 암호체계는 공개키와 개인키를 사용한다. 암호화·전자서명·키 합의는 목적과 알고리즘이 다르므로 모든 공개키 연산을 "개인키로 암호화"라고 부르면 부정확하다.

기밀성 목적의 전형적 설명에서는 수신자의 공개키로 보호한 정보를 수신자의 개인키로 복호화한다. 전자서명에서는 서명자의 개인키로 서명하고 대응 공개키로 검증한다. ECDSA와 EdDSA 같은 서명 알고리즘은 RSA 암호화와 같은 연산이 아니다. 시험의 단순 설명을 이해하되 실제 구현에서는 검증된 라이브러리와 표준 프로토콜을 사용한다.

해시와 MAC

암호학적 해시는 임의 길이 입력을 고정 길이 값으로 매핑하는 함수다. 역상 저항성, 제2역상 저항성, 충돌 저항성의 개념을 구별한다. 압축된 출력 공간이 유한하므로 수학적으로 충돌은 존재한다. 보안 목표는 현실적으로 유효한 충돌이나 역상을 찾기 어렵게 만드는 것이다.

키 없는 해시만 파일 옆에 두면 공격자가 파일과 해시를 함께 바꿀 수 있다. HMAC 등 MAC는 비밀키를 가진 주체가 메시지의 무결성과 인증을 확인하게 한다. MAC는 공유키를 가진 모든 사람이 만들 수 있어서 제3자에게 서명자 한 명의 행위를 입증하는 전자서명과 같은 부인방지 특성을 일반적으로 제공하지 않는다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

보완 B02 → 114쪽

정보보안 022회차 | 06-03 원리ㅍ

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 22/80회차 · 기록 묶음 05의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

전자서명은 무결성과 서명자 인증, 조건이 갖추어진 경우 부인방지에 기여한다. 서명만으로 메시지 내용의 기밀성이 생기는 것은 아니다. 실제 부인방지에는 개인키 보호·인증서·신뢰할 수 있는 시간·감사 체계 등 운영 조건도 영향을 준다.

비밀번호와 해시 저장

비밀번호 저장에는 일반적인 빠른 해시 한 번보다 salt와 적절한 작업 비용을 갖춘 전용 비밀번호 해시 기법이 필요하다. Argon2id·bcrypt·PBKDF2 등의 선택은 환경·정책·표준을 확인한다. salt는 사용자별 값으로 사전 계산과 동일 비밀번호 패턴을 어렵게 하지만 공개될 수 있다. pepper는 별도로 보호하는 비밀값이라는 점에서 구별한다. 특정 최소 파라미터는 변할 수 있으므로 이 교재에 고정 숫자로 암기하지 않는다.

단계별 예제: 파일의 세 보호 방식

거래 파일과 SHA-256 값만 공개 저장소에 둔다. 값이 일치하면 우발적 전송 손상 탐지에 도움은 되지만 악의적인 두 값의 동시 변경을 막지 못한다. 공유키로 MAC를 붙이면 키 없는 공격자의 변경을 탐지할 수 있다. 담당자의 개인키로 서명하면 공개키를 가진 검증자가 서명을 확인할 수 있다. 파일 내용까지 숨기려면 별도의 암호화가 필요하다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 023회차 | 06-03 예제·적용

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 23/80회차 · 기록 묶음 05의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

키 공간 계산

가상 키 길이가 8비트라면 가능한 키는 2^8=256개다. 9비트는 512개라서 한 비트 증가 시 두 배가 된다. n비트는 2^n개다. 실제 보안 강도는 키 길이뿐 아니라 알고리즘의 구조·취약점·모드·난수·키 관리에 영향을 받으므로 128비트 대칭키와 128비트 RSA를 같은 안전성으로 비교하지 않는다. 무작위 추측으로 평균 절반의 키를 시도한다는 단순 모형도 문제에서 가정할 때만 쓴다.

자가 연습과 풀이

전자서명이 검증되었으니 파일 내용을 아무도 읽지 못한다는 말은 틀리다. 서명과 암호화의 목적을 혼동했다. salt를 비밀키처럼 숨겨야만 안전하다는 주장도 정확하지 않다. salt의 역할과 별도 비밀 관리의 역할이 다르다.

완료 기준

네 가지 도구를 목적별로 배치해보자. 내용 숨김은 암호화, 비키 해시의 주요 역할은 지문·손상 탐지, 공유 비밀 기반 인증은 MAC, 공개 검증 가능한 서명은 전자서명이다.

응용 계산: 키 탐색과 해시 충돌은 다르다

n비트 키의 전체 공간은2^n이다. 이상적인 n비트 해시에서 생일 역설에 따른 충돌 탐색 규모는 대략2^(n/2) 관점으로 설명한다. 이것은 특정 입력의 역상을 찾는 문제와 다르다. 16비트 가상 해시는65536개 출력을 갖지만 충돌은 대략 수백 개 규모의 무작위 표본에서 가능성이 커지는 현상을 볼 수 있다. '256개면 반드시 충돌'처럼 결정적 보장으로 쓰지는 않는다.

역상 저항성은 주어진 해시값의 입력 찾기, 제2역상은 주어진 입력과 다른 같은 해시 입력 찾기, 충돌 저항성은 같은 해시의 임의 두 입력 찾기다. 시험 문장의 '입력이 이미 정해져 있는가'를 확인하면 세 개념을 구분하기 쉽다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 024회차 | 06-03 직접 문제

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 24/80회차 · 기록 묶음 05의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q07

전자서명만 적용했을 때 일반적으로 자동 보장되지 않는 것은?

1. 서명 검증에 따른 무결성 확인

2. 공개키를 통한 서명 검증

3. 서명자의 개인키에 의한 서명 생성

4. 메시지 내용의 기밀성

내 선택·근거: _____

B06Q08

파일과 키 없는 해시를 공격자가 모두 수정할 수 있을 때 옳은 설명은?

1. 해시가 있으므로 모든 악의적 변조가 막힌다.

2. 해시는 모든 입력에 서로 다른 값을 보장한다.

3. 파일과 해시를 함께 바꾸면 단순 비교를 통과할 수 있다.

4. 해시를 역변환하면 비밀번호가 항상 복원된다.

내 선택·근거: _____

B06Q09

가상 키 길이가 8비트에서 9비트로 늘면 가능한 키 수는?

1. 256개에서 512개

2. 256개에서 257개

3. 512개에서 256개

4. 항상 동일

내 선택·근거: _____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 025회차 | 06-03 해설·재현

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 25/80회차 · 기록 묶음 05의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

먼저 직접 푼 뒤 확인합니다.

B06Q07

정답: 4번

서명은 내용을 숨기는 암호화가 아니다. 무결성·서명자 인증에 기여하지만 키 보호 등 운영 조건도 필요하다.

B06Q08

정답: 3번

신뢰할 수 없는 위치에서 두 값을 함께 바꾸면 무결성 비교가 의미를 잃을 수 있다. 충돌은 수학적으로 존재하고 암호학적 해시는 복호화 기능이 아니다.

B06Q09

정답: 1번

가능한 키 수는 2^n이므로 2^8=256,2^9=512다. 실제 알고리즘 안전성은 키 길이만으로 결정되지 않는다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 026회차 | 06-03 원리 I

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 26/80회차 · 기록 묶음 06의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

강화 손풀이: 무결성 증거와 공유키의 한계

파일과 키 없는 해시를 같은 수정 가능한 경로에 두면 공격자가 둘을 바꿀 수 있다. 수신자는 별도 신뢰 경로의 해시나 키 기반 검증 등 신뢰 기준이 필요하다. MAC은 공유키를 아는 상대 사이의 변조 검증에 쓰이지만 양쪽 모두 유효 MAC을 만들 수 있어 어느 쪽이 작성했는지 제 3자에게 구별하는 서명과 같은 증거가 아니다. 서명도 키 신뢰·보관·유출 여부를 확인해야 한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 027회차 | 06-03 원리II

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 27/80회차 · 기록 묶음 06의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

실제 암호 대신 4비트 XOR 연습을 한다. C1=P1 XOR K, C2=P2 XOR K이고 C1=1010,C2=0110이면 C1 XOR C2=1100=P1 XOR P2다. P1=0110을 알면 P2=1100 XOR 0110=1010으로 드러난다. 같은 마스크를 재사용하면 키를 직접 몰라도 두 평문의 관계가 남는 반례다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 028회차 | 06-03 예제·적용

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 28/80회차 · 기록 묶음 06의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

실무 암호는 검증된 라이브러리와 올바른 모드·키·nonce 조건을 따른다. GCM에서는 같은 키의 IV/nonce 유일성 조건을 지켜야 한다. 인증 태그 검증 실패를 성공으로 바꾸거나 검증되지 않은 평문을 업무에 사용하지 않는다. XOR 예제는 실제 암호 구현 처방이 아니다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 029회차 | 06-03 직접 문제

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 29/80회차 · 기록 묶음 06의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이·서술형 작성
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개와 서술형 1개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q31

두 당사자가 같은 MAC 키를 안다. MAC만으로 제3자에게 어느 한 당사자만 메시지를 작성했다고 증명하기 어려운 이유는?

1. MAC이 평문을 항상 암호화함

2. MAC은 무조건 전자서명과 동일함

3. MAC은 항상 키 없이 계산됨

4. 두 당사자 모두 유효 MAC을 만들 수 있음

내 선택·근거: _____

B06Q32

4비트 XOR 연습에서 C1=1010, C2=0110이고 같은 마스크를 썼다. C1 XOR C2는?

1. 0011

2. 1110

3. 1100

4. 0100

내 선택·근거: _____

B06Q33

파일과 키 없는 해시를 공격자가 둘 다 수정할 수 있다. 단순 비교의 한계를 보완하는 관점은?

1. 해시 문자열을 파일 옆에 한 번 더 복사

2. 파일 이름에 안전이라고 표시

3. 해시가 존재하면 항상 정품

4. 별도 신뢰 경로의 검증 기준 또는 적절한 키 기반 검증을 사용

내 선택·근거: _____

W06Q03

같은 XOR 마스크로 만든 C1=1010, C2=0110이고 P1=0110이다. P2를 구하고 재사용 위험, MAC과 서명의 증거 조건을 설명하라.

조건·원리·중간 과정·결론 순서로 먼저 답안을 작성합니다.

내 답안: _____

_____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 030회차 | 06-03 해설·재현

암호의 기초: 암호화·해시·MAC·전자서명 · 과목 30/80회차 · 기록 묶음 06의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

서술형 모범답안과 자가 채점 기준

B06Q31

정답: 4번

정답 근거: 공유 키 보유자 모두 생성할 수 있으므로 한 명의 단독 작성 증거와 다르다.

「MAC은 항상 키 없이 계산됨」- MAC은 키를 사용하는 인증 코드다.

「MAC이 평문을 항상 암호화함」- MAC 자체는 내용의 기밀성을 자동 제공하지 않는다.

「MAC은 무조건 전자서명과 동일함」- 공유 키 인증과 개인 서명 키의 증거 조건은 다르다.

B06Q32

정답: 3번

정답 근거: 왼쪽부터 1 XOR 0=1, 0 XOR 1=1, 1 XOR 1=0, 0 XOR 0=0으로 1100이다.

「0011」- 왼쪽 두 비트와 오른쪽 두 비트의 결과가 바뀌었다.

「1110」- 왼쪽에서 세 번째 1 XOR 1은 0이며 1이 아니다.

「0100」- 첫 번째 1 XOR 0은 1이고 두 번째 0 XOR 1도 1이다.

B06Q33

정답: 4번

정답 근거: 검증 대상과 신뢰 기준의 수정 경계를 분리하고 검증 키의 신뢰도 확인한다.

「해시 문자열을 파일 옆에 한 번 더 복사」- 같은 수정 권한 아래의 복사본도 공격자가 바꿀 수 있다.

「파일 이름에 안전이라고 표시」- 이름은 내용 무결성의 증거가 아니다.

「해시가 존재하면 항상 정품」- 공격자가 변조 파일에 맞춰 해시를 다시 계산할 수 있다.

W06Q03

같은 XOR 마스크로 만든 C1=1010, C2=0110이고 P1=0110이다. P2를 구하고 재사용 위험, MAC과 서명의 증거 조건을 설명하라.

모범답안

C1 XOR C2=1100=P1 XOR P2이므로 P2=1100 XOR 0110=1010이다. 같은 마스크는 평문 관계를 노출한다. MAC 공유 키는 두 보유자 모두 생성할 수 있으므로 한 보유자만의 작성이라는 제3자 증거와 다르다. 서명은 서명 개인키 통제와 검증 공개키의 신원·신뢰 조건을 확인해야 하며 서명 존재만으로 모든 법적 효과를 확정하지 않는다. 실제 암호는 검증된 방식과 nonce·키 조건을 사용한다.

10점 자가 채점 기준

- 4점: 중간 XOR 1100을 2점, P2=1010을 2점으로 계산한다.
- 3점: 같은 마스크가 상쇄됨 1점, 평문 XOR 관계 노출 1점, 알려진 P1으로 P2 계산 가능 1점을 설명한다.
- 3점: MAC 양쪽 생성 가능 1점, 서명 개인키 통제 1점, 검증키 신뢰 조건 1점을 구분한다.

점수는 학습용 자가 채점이며 실제 시험 배점 재현이 아닙니다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 031회차 | 06-04 원리 I

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 31/80회차 · 기록 묶음 07의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

인증서와 신뢰

인증서는 공개키와 주체 정보를 서명으로 연결하는 문서다. CA의 서명 확인만 해서는 충분하지 않을 수 있다. 신뢰할 수 있는 경로, 유효기간, 호스트 이름, 사용 목적, 필요한 폐기·상태 확인 정책 등을 검증한다. 화면에 자물쇠 표시가 있다는 사실만으로 서비스의 사업 내용이나 모든 프로그램 코드가 안전하다고 보장하지는 않는다.

인증서 체인은 서버 인증서에서 중간 CA를 거쳐 신뢰 저장소의 루트까지 연결된다. 루트의 신뢰는 해당 기기·운영 환경의 신뢰 저장소 정책과 관련된다. 자기서명 인증서라는 이유만으로 모든 내부 활용이 불가능한 것은 아니지만 외부 사용자에게 자동 신뢰되는 것은 아니다.

TLS의 큰 흐름

TLS는 통신 상대 인증과 안전한 키 협상, 전송 데이터 보호를 제공한다. 일반적인 웹 연결에서는 서버를 인증하고, 클라이언트 인증서를 사용하는 상호 TLS는 별도 구성을 한다. TLS 1.3은 암호 스위트와 핸드셰이크가 과거 버전과 다르므로 RSA 키로 모든 세션키를 직접 암호화해 전송한다는 설명을 최신 TLS 전체에 적용하지 않는다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

보완 B05 → 117쪽

정보보안 032회차 | 06-04 원리II

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 32/80회차 · 기록 묶음 07의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

개념적으로 클라이언트와 서버가 지원 값을 협상하고, 키 공유와 서버의 인증 정보를 검증하며, 합의한 비밀로 트래픽 키를 유도한다. 실제 데이터 보호에는 AEAD 계열처럼 암호화와 무결성 검증을 결합한 방식이 사용된다. 디지털 인증서·서명은 신뢰 확인, 대칭키 보호는 효율적인 데이터 전송에 기여한다.

전방향 안전성은 장기 개인키가 나중에 노출되어도 과거 세션의 비밀이 자동으로 복구되지 않도록 하는 특성과 관련된다. 임시 키 교환과 안전한 키 삭제 같은 조건이 중요하다. "서버 개인키가 유출되어도 미래 공격도 모두 불가능하다"는 뜻은 아니다.

키의 생명주기

키 생성에는 암호학적으로 안전한 난수가 필요하다. 저장·사용·분배·회전·폐기·복구 정책을 함께 관리한다. 소스 코드에 키를 그대로 넣거나 같은 nonce를 반복 사용하는 것은 알고리즘이 강해도 전체 시스템을 취약하게 만들 수 있다. 인증서 만료 갱신, 키 유출 시 교체, 접근 기록과 최소권한도 키 관리에 들어간다.

암호 모드와 IV/nonce의 조건은 알고리즘별로 다르다. "IV는 항상 비밀이어야 한다"처럼 일반화하지 않는다. 특히 일부 AEAD 방식의 nonce 재사용은 심각한 위험을 만들 수 있으므로 도구의 계약을 지켜야 한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 033회차 | 06-04 예제·적용

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 33/80회차 · 기록 묶음 07의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

단계별 상황 예제

내부 개발자는 HTTPS 오류를 피하려고 인증서 검증을 껐다. 암호화된 연결은 만들어질 수 있지만 상대가 진짜 서버인지 확인하지 못하면 중간자 공격 위험이 커진다. 올바른 해결은 개발 환경의 신뢰 경로·호스트 이름·유효기간을 맞추는 것이다. 오류 무시 코드를 운영에 남기면 보안 목표를 훼손한다.

인증서가 10월 10일 만료이고 갱신 후 재시작이 필요한 가상 서비스에서 10월 9일 마지막 점검만 하면 갱신 실패와 롤백 시간이 부족할 수 있다. 만료 전에 갱신·배포·실제 연결 시험을 계획하고 경보를 걸어야 한다. 날짜는 학습용 예시이며 기관 정책을 뜻하지 않는다.

자가 연습과 풀이

TLS가 적용되었는데 서버 로그에 비밀번호를 평문으로 남겼다. 전송 구간의 보호는 서버 저장 데이터의 안전을 자동으로 보장하지 않는다. 전송 중·저장 중·사용 중의 경계를 각각 확인해야 한다.

완료 기준

공개키 인증서와 대칭키 데이터 보호의 역할을 구분하고 인증서 검증을 껐을 때 어떤 목표가 훼손되는지 설명한다. TLS는 모든 응용 프로그램 취약점의 해결책이 아니라는 점도 사례로 말할 수 있어야 한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 034회차 | 06-04 직접 문제

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 34/80회차 · 기록 묶음 07의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q10

HTTPS 인증서 검증을 꺼서 오류를 무시했을 때 가장 적절한 평가는?

1. 암호화 연결이므로 상대 인증도 자동으로 완벽하다.

2. 응용 프로그램의 모든 권한 취약점이 사라진다.

3. 서버의 진위를 확인하는 신뢰가 약해져 중간자 위험이 커질 수 있다.

4. CA의 개인키를 클라이언트에 복사하면 안전하다.

내 선택·근거: _____

B06Q11

일반적인 TLS 연결과 서버 로그의 관계로 옳은 것은?

1. TLS가 있으면 평문 로그의 정보도 자동 암호화된다.

2. TLS는 서버의 모든 소스 코드를 검증한다.

3. 전송 구간 보호와 서버 저장 로그 보호는 별도 설계가 필요하다.

4. TLS를 쓰면 비밀번호 저장 방식은 상관없다.

내 선택·근거: _____

B06Q12

전방향 안전성의 핵심 의미에 가장 가까운 것은?

1. 미래의 모든 공격을 반드시 막는 특성

2. 장기 키가 나중에 노출돼도 과거 세션 비밀의 복구가 자동으로 가능해지지 않도록 하는 특성

3. 같은 nonce를 항상 재사용하는 특성

4. 인증서를 영구히 갱신하지 않아도 되는 특성

내 선택·근거: _____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 035회차 | 06-04 해설·재현

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 35/80회차 · 기록 묶음 07의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

먼저 직접 푼 뒤 확인합니다.

B06Q10

정답: 3번

암호화와 상대 인증을 구분한다. 검증 중단은 신뢰 경로·호스트 확인을 무력화할 수 있으며 CA 개인키 복사는 심각한 비밀 노출이다.

B06Q11

정답: 3번

TLS의 보호 경계를 넘는 저장 데이터·앱 로직·비밀번호 저장은 별도로 보호한다. 네트워크 보호 하나로 전체 보안을 확대 해석하지 않는다.

B06Q12

정답: 2번

과거 세션 보호가 핵심이며 임시 키 교환·키 관리 등 조건이 필요하다. 미래 공격 전면 방지·nonce 재사용·인증서 영구화와 다르다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 036회차 | 06-04 원리 I

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 36/80회차 · 기록 묶음 08의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

응용 문제: 인증서와 키를 함께 점검하기

유효한 인증서를 제시했지만 접속 호스트 이름이 인증서의 허용 이름과 맞지 않으면 정상 검증을 통과하지 못할 수 있다. 반대로 이름만 맞아도 신뢰 경로·기간·사용 목적 조건이 빠지면 충분하지 않다. 자기서명 여부 하나만으로 모든 검증을 대체하지 않는다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 037회차 | 06-04 원리II

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 37/80회차 · 기록 묶음 08의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

장기 키 유출 시에는 해당 키를 교체하고 인증서·토큰·관련 접근을 정책에 따라 재검토한다. 키 회전은 단순히 새 키를 만드는 작업만이 아니라 새 키 적용·기존 자료 처리·옛 키 사용 종료·복구 가능성 확인을 포함한다. 오래된 암호문을 복호화해야 하는 요구와 노출 키의 사용 중단을 함께 설계해야 한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 038회차 | 06-04 예제·적용

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 38/80회차 · 기록 묶음 08의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

강화 통신·키 관리: 세 검사를 하나로 뭉치지 않기

가상 서비스는 서버 인증서의 신뢰 경로·요청 서버 이름·유효 조건을 확인한 뒤 통신한다. 신뢰된 발급자가 서명했어도 요청한 호스트와 이름이 다르면 그 서버의 신원 검증을 통과한 것이 아니다. TLS 사용만으로 애플리케이션의 객체 권한과 로그 보호가 해결되지 않는다.

봉투 암호화 예제에서는 자료를 DEK로 암호화하고, DEK를 KEK로 보호한다. KEK를 교체할 때 DEK 자체를 바꾸지 않고 새 KEK로 재포장하는 방식과 자료까지 새 DEK로 재암호화하는 방식을 구분한다. 재포장만 했다면 DEK 사용 기간·사용량 제한이 새로 시작된다고 단정하지 않는다. 이전 복호 경로는 이행 검증·백업 복구 조건을 확인한 뒤 정책에 따라 정리한다.

손풀이 반례: 프로세스별 nonce 카운터를 0부터 시작하고 같은 키로 두 프로세스를 실행하면 둘 다 첫 nonce 0을 쓸 수 있다. 재시작·다중 서버까지 포함해 유일성을 설계한다. 암호키를 코드 저장소와 암호문 옆 파일에 같은 권한으로 저장하면 저장소 침해로 둘 다 노출될 수 있다. 키 식별자·권한·변경 기록·복구 경로를 함께 관리한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 039회차 | 06-04 직접 문제

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 39/80회차 · 기록 묶음 08의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이·서술형 작성
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개와 서술형 1개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q34

TLS 서버 인증서가 신뢰된 발급자로부터 왔지만 요청 호스트와 이름이 다르다. 적절한 판단은?

1. 검증을 꺼야 보안 향상

2. 발급자만 맞으면 항상 통과

3. 이름 검증 실패를 무시하지 않고 접속 조건을 확인

4. HTTPS 글자만 있으면 통과

내 선택·근거: _____

B06Q35

같은 GCM 키를 쓰는 두 프로세스가 동일한 nonce 생성 규칙과 카운터를 각각 0에서 시작한다. 핵심 문제는?

1. nonce가 비밀이어야만 중복이 문제

2. 재시작이 모든 암호문을 자동 보호

3. 같은 키에서 nonce가 중복될 수 있음

4. 프로세스가 다르면 자동으로 유일

내 선택·근거: _____

B06Q36

DEK로 자료를 암호화하고 KEK로 DEK를 보호한다. DEK는 유지한 채 새 KEK로 재포장했다. 정확한 설명은?

1. 자료 암호문을 유지할 수 있으며 DEK 사용 조건이 자동 초기화되지는 않음

2. 모든 자료가 반드시 새 DEK로 재암호화됨

3. DEK 사용 기간이 자동 0으로 초기화됨

4. 키 검증과 복원 시험이 불필요함

내 선택·근거: _____

W06Q04

TLS 호스트 이름 불일치와 같은 GCM 키 아래 동일 nonce 카운터 재시작 문제를 설명하라. DEK는 유지하고 KEK만 바꿀 때 확인할 조건도 쓰라.

조건·원리·중간 과정·결론 순서로 먼저 답안을 작성합니다.

내 답안: _____

_____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 040회차 | 06-04 해설·재현

PKI·TLS·키 관리: 안전한 통신의 조건 · 과목 40/80회차 · 기록 묶음 08의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

서술형 모범답안과 자가 채점 기준

B06Q34

정답: 3번

정답 근거: 신뢰 경로뿐 아니라 요청 대상의 이름과 유효 조건을 함께 확인한다.

「발급자만 맞으면 항상 통과」- 신뢰된 발급자와 요청 대상의 신원 일치는 별도 조건이다.

「HTTPS 글자만 있으면 통과」- 표시된 글자는 인증서 조건의 검증을 대신하지 않는다.

「검증을 꺼야 보안 향상」- 검증 해제는 상대 신원 확인을 약화한다.

B06Q35

정답: 3번

정답 근거: 두 프로세스의 동일한 카운터 값이 같은 키 아래 같은 nonce를 만들 수 있다.

「프로세스가 다르면 자동으로 유일」- 프로세스 구분 정보가 생성 규칙에 들어간다는 조건은 없고 동일 규칙이다.

「nonce가 비밀이어야만 중복이 문제」- 여기서 핵심은 같은 키 아래의 nonce 유일성이다.

「재시작이 모든 암호문을 자동 보호」- 카운터 초기화는 이전 nonce를 다시 만드는 원인이 될 수 있다.

B06Q36

정답: 1번

정답 근거: KEK 재포장과 DEK 교체를 구분한다. DEK 자체의 사용 이력과 제한은 그대로 검토한다.

「모든 자료가 반드시 새 DEK로 재암호화됨」- DEK를 그대로 둔다고 명시했으므로 새 DEK 재암호화는 필수 결과가 아니다.

「DEK 사용 기간이 자동 0으로 초기화됨」- 재포장은 DEK의 사용 이력을 지우지 않는다.

「키 검증과 복원 시험이 불필요함」- 이행 후 복호와 복구 가능성을 확인해야 한다.

W06Q04

TLS 호스트 이름 불일치와 같은 GCM 키 아래 동일 nonce 카운터 재시작 문제를 설명하라. DEK는 유지하고 KEK만 바꿀 때 확인할 조건도 쓰라.

모범답안

신뢰된 발급자라는 사실만으로 다른 호스트 이름의 인증서를 허용하지 않는다. 같은 키와 생성 규칙에서 카운터를 초기화하면 과거 또는 다른 프로세스의 nonce와 중복될 수 있다. KEK 재포장은 DEK 교체와 다르며 DEK 사용 이력이 자동 초기화되지 않는다. 키 식별자·이행 상태·복호·백업 복원 가능성을 검증한다.

10점 자가 채점 기준

- 3점: 요청 호스트 이름 검사 1점, 발급자 신뢰만으로 이름 불일치 허용 불가 2점을 설명한다.
- 4점: 동일 키 조건 1점, 카운터 초기화 1점, 과거/다중 프로세스 중복 가능성과 유일성 설계 2점을 쓴다.
- 3점: 재포장과 DEK 교체 구분 1점, DEK 이력 유지 1점, 복호·복원 검증 1점을 제시한다.

점수는 학습용 자가 채점이며 실제 시험 배점 재현이 아닙니다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 041회차 | 06-05 원리 I

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 41/80회차 · 기록 묶음 09의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

SQL 주입

SQL 주입은 신뢰할 수 없는 입력이 SQL의 데이터 자리를 넘어 명령 구조에 영향을 주는 취약점이다. 핵심 예방은 파라미터 바인딩·준비된 문장 등으로 명령과 값을 분리하고, DB 계정에 최소권한을 적용하는 것이다. 입력의 따옴표를 제거하는 임시 처리만으로 모든 문법·인코딩·맥락 문제를 해결할 수 없다.

값 자리의 파라미터 바인딩이 테이블명·열명·정렬 방향 같은 SQL 구조를 자동으로 보호하는 것은 아니다. 그런 구조는 허용 목록에서 선택한다. 저장 프로시저도 내부에서 안전하지 않은 동적 SQL을 만들면 자동으로 안전하지 않다.

XSS

XSS는 신뢰할 수 없는 데이터가 웹 문서의 실행 가능한 문맥으로 들어가 공격자가 의도한 스크립트가 실행되는 문제다. 저장형은 악성 값이 서버 등에 저장됐다가 표시되고, 반사형은 요청 입력이 응답에 돌아오며, DOM 기반은 클라이언트 코드의 처리 흐름에서 문제가 생긴다. 분류가 실제 사건에서 겹칠 수 있다.

예방은 출력 위치에 맞는 인코딩, 안전한 DOM API, 필요하면 검증된 HTML 정화 도구, 보조적인 CSP 등으로 구성한다. HTML 본문·속성·JavaScript·URL은 문맥이 다르다. 모든 위치에 같은 인코딩 함수를 적용하면 안 된다. HttpOnly는 JavaScript가 쿠키를 직접 읽지 못하도록 돕지만 XSS가 사용자를 대신해 요청을 보내는 모든 행동을 막는 것은 아니다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

보완 B04 → 116쪽

정보보안 042회차 | 06-05 원리ㅍ

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 42/80회차 · 기록 묶음 09의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

CSRF

CSRF는 인증된 사용자의 브라우저가 자동으로 보내는 인증 정보를 이용해 사용자가 원하지 않는 상태 변경 요청을 수행하게 하는 공격이다. 쿠키 기반 인증에서 특히 중요한 맥락이다. 서버는 CSRF 토큰 검증, 적절한 SameSite 정책, 요청 출처 확인, 중요 작업의 재확인 등을 설계할 수 있다. 토큰을 생성만 하고 서버에서 검사하지 않으면 방어가 아니다.

CSRF와 XSS는 다르다. CSRF는 대상 사이트의 스크립트 주입을 반드시 필요로 하지 않는다. XSS가 존재하면 일부 CSRF 방어를 우회할 수 있으므로 하나만 해결해 전체 웹 보안이 끝났다고 보지 않는다. GET을 상태 변경에 쓰지 않는다는 규칙도 잘못된 인증·인가를 대신하지는 않는다.

세 가지 사례를 비교

첫째, 계정 조회 SQL에 입력 문자열을 붙여 쿼리 구조가 달라졌다면 SQL 주입이다. 둘째, 게시판에 저장한 문자열이 화면에서 스크립트로 실행됐다면 저장형 XSS다. 셋째, 다른 사이트가 로그인된 브라우저를 통해 이체 요청을 보내도록 만들었다면 CSRF 시나리오다. 어느 사건인지 먼저 판단한 뒤 방어를 연결한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 043회차 | 06-05 예제·적용

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 43/80회차 · 기록 묶음 09의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

방어 설계 예제

신청서 검색 기능에서 검색어는 SQL 파라미터로 전달한다. 정렬 열은 allowedSort={name,date}라는 허용 목록에서 고른다. 결과 화면의 고객 이름은 텍스트 문맥으로 안전하게 출력한다. 승인 POST 요청은 권한 검사와 CSRF 검증을 한다. SQL 파라미터를 적용했다고 출력 화면의 XSS가 해결되지는 않는다. 방어가 적용되는 경계가 각각 다르다.

숫자·자가 연습

100개 입력 중 5개를 금지 문자열 목록으로 막았다는 사실만으로 나머지 95개가 안전하다고 증명할 수 없다. 블랙리스트 탐지율을 시스템의 완전한 안전성과 동일시하지 않는다. 강한 핵심 통제와 의미 있는 테스트를 함께 적용한다.

자가 연습: 검색 결과에 사용자 입력을 보여주는 페이지에서 SQL은 파라미터를 사용한다. XSS 검토도 필요할까? 필요하다. DB 명령 구조 보호와 브라우저 실행 문맥 보호는 별개의 문제다.

완료 기준

공격마다 입력이 어느 경계를 넘어 실행 의미를 얻는지 설명하고 SQL 주입→파라미터화, XSS→문맥에 맞는 출력 처리, CSRF→요청 진위 검증을 연결할 수 있어야 한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 044회차 | 06-05 직접 문제

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 44/80회차 · 기록 묶음 09의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q13

검색어를 SQL 값으로 안전하게 전달하는 핵심 방법은?

1. 모든 오류를 숨기기만 한다.

2. HTML 출력만 인코딩한다.

3. 파라미터 바인딩으로 명령과 값을 분리한다.

4. 정렬 열을 사용자가 임의 문자열로 넣게 한다.

내 선택·근거: _____

B06Q14

게시판에 저장한 내용이 조회 시 스크립트로 실행되는 취약점은?

1. 저장형 XSS

2. 단순 네트워크 압축

3. CSRF만

4. 키 회전

내 선택·근거: _____

B06Q15

쿠키 인증을 사용하는 승인 요청에서 CSRF 방어에 직접 관련된 것은?

1. 요청의 CSRF 토큰을 서버에서 검증

2. SQL 조회 결과의 개수 제한만

3. SHA 해시를 화면에 표시만

4. 관리 메뉴를 숨기기만

내 선택·근거: _____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 045회차 | 06-05 해설·재현

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 45/80회차 · 기록 묶음 09의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

먼저 직접 푼 뒤 확인합니다.

B06Q13

정답: 3번

SQL 주입의 핵심 경계는 명령 구조와 데이터다. 출력 인코딩은 XSS와 연결되고 정렬 열 등 구조 입력에는 허용 목록이 필요하다.

B06Q14

정답: 1번

저장된 입력이 브라우저 실행 문맥으로 들어가는 저장형 XSS다. CSRF는 사용자 브라우저의 인증 정보를 이용한 원치 않는 요청과 관련된다.

B06Q15

정답: 1번

서버 측 토큰 검증은 요청 진위를 확인하는 방어다. 생성·표시만 하고 검사하지 않으면 의미가 없으며 다른 통제는 목적이 다르다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 046회차 | 06-05 원리 I

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 46/80회차 · 기록 묶음 10의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

응용 문제: CORS와 CSRF의 차이

CORS는 브라우저에서 다른 출처의 응답을 읽는 것 등에 관한 통제다. 단순히 CORS를 설정했다고 모든 원치 않는 요청이 보내지지 않는 것은 아니다. CSRF는 인증 정보가 자동 첨부되는 상태 변경 요청의 진위 문제다. 허용 출처와 인증 방식·토큰 검증·쿠키 속성의 관계를 함께 확인한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 047회차 | 06-05 원리ㅍ

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 47/80회차 · 기록 묶음 10의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

파라미터 바인딩은 입력 문자열을 SQL 값으로 취급하지만 저장된 값이 나중에 HTML에서 실행되면 XSS는 여전히 생길 수 있다. 입력 검증·SQL 파라미터화·출력 인코딩·CSRF·인가 검사는 모두 다른 경계를 보호한다. 한 방어를 적용했으니 다른 검토는 필요 없다는 선택지를 경계하자.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 048회차 | 06-05 예제·적용

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 48/80회차 · 기록 묶음 10의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

강화 입력·출력 경계: 값과 SQL 구조는 다르다

가상 검색 API는 검색어 값을 매개변수로 보내고 정렬 항목은 외부 값 date/name을 내부 고정 열 created_at/customer_name에 대응시킨다. 미등록 정렬 항목은 거절한다.

1. 검색어는 자료 값이므로 SQL 문자열과 분리해 바인딩한다.

2. 열 이름·ASC/DESC 같은 SQL 구조는 일반 값 바인딩으로 대신할 수 없으므로 허용된 고정 선택으로 구성한다.

3. 실행 계정 권한과 객체 접근 조건을 별도로 확인한다.

검색어 매개변수화가 있어도 정렬 문자열을 그대로 이어 붙이는 반례는 구조 경계를 남긴다.

게시 내용은 출력되는 HTML 본문·속성·스크립트 문맥에 맞는 방어가 필요하다. 문자열에 'script'가 없다는 검사는 충분하지 않다. 일반 텍스트 표시 목적이면 텍스트용 안전한 출력 경로를 사용하고 HTML 허용이 필요하면 검증된 정제 정책을 적용한다. CSRF 방어는 상태 변경 요청의 요청 출처·토큰 등을 검증하는 별도 문제이며 XSS가 있으면 일부 방어를 우회할 수 있다. POST라는 메서드 이름만으로 안전성을 확정하지 않는다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 049회차 | 06-05 직접 문제

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 49/80회차 · 기록 묶음 10의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이·서술형 작성
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개와 서술형 1개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q37

검색어 값은 매개변수화하지만 정렬 열은 사용자 문자열을 SQL에 붙인다. 적절한 보완은?

1. 외부 정렬 선택을 허용된 고정 열 이름에 대응하고 미등록 값 거절

2. 모든 열 이름을 일반 문자열 값 바인딩으로 해결

3. 검색어만 안전하면 정렬도 자동 안전

4. script 문자만 삭제

내 선택·근거: _____

B06Q38

게시 내용은 일반 텍스트 표시가 목적이다. XSS 방어에 가장 직접적인 구현 방향은?

1. 해당 출력 문맥에 맞는 안전한 텍스트 출력 사용

2. 로그인 사용자 내용은 항상 신뢰

3. 비밀번호 해시 함수로 게시 내용 확인

4. script 단어가 없으면 HTML로 실행

내 선택·근거: _____

B06Q39

쿠키 인증을 쓰는 상태 변경 요청을 POST로 보낸다. 이 사실만으로 CSRF 안전성이 확정되는가?

1. 쿠키는 반드시 수동 전송됨

2. SQL 매개변수화가 CSRF도 해결

3. POST는 외부 사이트에서 보낼 수 없음

4. 아니며 합의한 토큰·출처 등 요청 검증이 필요

내 선택·근거: _____

W06Q05

검색어는 값 바인딩하지만 정렬 열은 외부 문자열을 이어 붙인다. 게시물은 텍스트 표시, 상태 변경은 쿠키 인증이다. 세 공격 경계와 방어를 연결하라.

조건·원리·중간 과정·결론 순서로 먼저 답안을 작성합니다.

내 답안: _____

_____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 050회차 | 06-05 해설·재현

웹 취약점: SQL 주입·XSS·CSRF를 구별하기 · 과목 50/80회차 · 기록 묶음 10의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

서술형 모범답안과 자가 채점 기준

B06Q37

정답: 1번

정답 근거: 일반 자료값 바인딩과 SQL 구조를 구분하고 구조 선택에는 고정 허용 목록 또는 재설계를 사용한다.

「모든 열 이름을 일반 문자열 값 바인딩으로 해결」- 열 식별자를 일반 값으로 바인딩하는 것이 의도한 SQL 구조 선택을 보장하지 않는다.

「검색어만 안전하면 정렬도 자동 안전」- 정렬 구조의 외부 입력 경계가 별도로 남는다.

「script 문자만 삭제」- 해당 문자열 삭제는 SQL 구조 검증을 대신하지 못한다.

B06Q38

정답: 1번

정답 근거: 텍스트가 실행 가능한 HTML 등으로 해석되지 않도록 출력 경계를 관리한다.

「비밀번호 해시 함수로 게시 내용 확인」- 비밀번호 해시는 출력 문맥의 실행 방어와 다르다.

「script 단어가 없으면 HTML로 실행」- 한 단어의 유무만으로 다양한 실행 문맥과 구문을 안전하게 검증하지 못한다.

「로그인 사용자 내용은 항상 신뢰」- 인증이 사용자 내용의 안전성을 보장하지 않는다.

B06Q39

정답: 4번

정답 근거: 인증 쿠키 보유와 요청자의 의도 검증은 같지 않다. 적절한 요청 검증이 필요하다.

「POST는 외부 사이트에서 보낼 수 없음」- POST라는 메서드만으로 외부에서 유발된 요청을 차단하지 않는다.

「쿠키는 반드시 수동 전송됨」- 브라우저가 쿠키를 전송하는 조건도 고려해야 한다.

「SQL 매개변수화가 CSRF도 해결」- SQL의 자료값 경계와 요청 의도의 경계는 다르다.

W06Q05

검색어는 값 바인딩하지만 정렬 열은 외부 문자열을 이어 붙인다. 게시물은 텍스트 표시, 상태 변경은 쿠키 인증이다. 세 공격 경계와 방어를 연결하라.

모범답안

검색값은 바인딩하고 정렬 구조는 허용된 고정 열에 대응시켜 미등록 값을 거절한다. 게시물은 해당 출력 문맥의 안전한 텍스트 경로를 사용한다. 쿠키 상태 변경은 POST만 믿지 않고 CSRF 토큰·출처 등 합의한 검증을 적용한다. 값/SQL 구조, 텍스트/실행 문맥, 인증/요청 의도를 각각 구분한다.

10점 자가 채점 기준

- 4점: SQL 값과 구조의 차이 2점, 고정 허용 열 대응 및 미등록 거절 2점을 쓴다.
- 3점: XSS의 출력 문맥 1점, 안전한 텍스트 표시 2점을 설명한다.
- 3점: POST만으로 불충분 1점, 토큰·출처 등 요청 검증 1점, 인증과 요청 의도 구분 1점을 쓴다.

점수는 학습용 자가 채점이며 실제 시험 배점 재현이 아닙니다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 051회차 | 06-06 원리 I

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 51/80회차 · 기록 묶음 11의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

세션 식별자와 수명

세션은 여러 요청 사이에서 인증 상태 등을 이어가는 방식이다. 서버 측 세션에서는 추측하기 어려운 식별자가 서버 상태를 가리킨다. 로그인·권한 상승 뒤 식별자를 갱신하는 것은 세션 고정 공격의 위험을 줄인다. 로그아웃은 사용자 화면만 바꾸는 것이 아니라 필요한 서버 측 무효화도 수행해야 한다.

Secure는 쿠키를 안전한 전송 조건에서 보내도록 하는 속성, HttpOnly는 스크립트가 쿠키를 직접 읽지 못하게 하는 속성, SameSite는 사이트 간 전송을 제한하는 속성이다. 속성의 정확한 작동과 브라우저 정책은 최신 문서를 확인한다. 쿠키 속성은 애플리케이션의 인가 검사를 대신하지 않는다.

JWT는 형식과 서명·클레임 검증의 체계이며 "내용이 항상 암호화된 토큰"이 아니다. 서명된 일반 JWT의 payload는 읽을 수 있다. 검증 시 허용 알고리즘·서명·발급자·대상·만료 등 해당 서비스에 필요한 조건을 확인한다. 토큰을 디코딩한 것과 검증한 것은 다르다. 만료 시간을 매우 길게 하면 탈취된 토큰의 영향도 커질 수 있다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 052회차 | 06-06 원리ㅍ

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 52/80회차 · 기록 묶음 11의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

객체 권한과 API

API에서 사용자 ID나 신청서 번호를 받아 처리할 때 요청자가 해당 객체에 접근할 수 있는지 검사한다. 경로가 /applications/902이고 버튼이 숨겨져 있어도 서버 측 검사가 빠지면 접근통제 문제가 남는다. 대량 요청에는 적절한 요청 제한·자원 제한·모니터링을 설계한다. 잘못된 오류 메시지로 계정 존재 여부나 내부 쿼리가 드러날 수 있다.

역직렬화·업로드·SSRF

신뢰할 수 없는 직렬화 입력을 임의 객체로 복원하면 예상치 못한 타입과 동작이 실행될 위험이 있다. 단순 데이터 형식, 허용 타입, 구조·크기 검증, 안전한 라이브러리를 사용하고 신뢰 경계를 분명히 한다. 모든 역직렬화가 곧 코드 실행이라는 뜻은 아니며 언어·형식·구현에 따라 위험이 다르다.

파일 업로드에서는 확장자만 보지 않고 내용·크기·저장 위치·실행 권한·이름·접근 권한을 확인한다. 경로 입력에서 ../ 등이 다른 디렉터리 접근으로 이어지는 경로 탐색도 고려한다. SSRF는 서버가 사용자 지정 주소 등에 요청하도록 유도되어 내부 자원 등에 접근하는 문제다. URL의 허용 목적지·스킴·네트워크 경계·리다이렉트 처리 등 통제가 중요하다.

단계별 사례: 토큰 유출

브라우저 저장소에 장기 토큰을 넣고 사이트에 XSS가 생겼다고 하자. 페이지에서 실행되는 악성 스크립트가 읽을 수 있는 저장소는 토큰 유출 위험이 있다. HttpOnly 쿠키 사용 등 구조적 선택을 검토할 수 있지만 그러면 쿠키 자동 전송에 따른 CSRF 맥락도 함께 검토한다. 저장 위치 한 가지만 고르면 모든 문제가 사라진다고 단정하지 않는다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 053회차 | 06-06 예제·적용

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 53/80회차 · 기록 묶음 11의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

토큰 payload에 고객 식별값과 비밀번호를 넣고 서명만 했다고 하자. 서명은 내용 숨김을 제공하지 않으므로 민감 값을 불필요하게 넣으면 안 된다. 전송 TLS, 토큰 내용 최소화, 수명, 갱신·폐기, 서버 권한 검사를 함께 설계한다.

입력 검증과 인코딩 구별

입력 검증은 데이터의 타입·범위·구조·업무 규칙을 확인한다. 출력 인코딩은 데이터가 특정 실행 문맥에서 명령으로 해석되지 않도록 표현한다. 둘은 목적과 위치가 다르다. 요청 크기 10MB 제한은 자원 소모를 줄일 수 있지만 저장된 텍스트의 XSS를 해결하지 않는다.

자가 연습과 풀이

관리 기능 URL을 복잡하게 만들고 메뉴에서 숨겼다. 충분한가? 아니다. 인가 검사를 서버에 적용하고 필요한 역할·대상·환경 조건을 확인한다. 모호한 URL은 추측을 어렵게 할 수 있으나 권한 통제 자체가 아니다.

완료 기준

쿠키 3속성·세션 고정·JWT 서명/암호화 차이를 설명하고, 객체 권한·역직렬화·업로드·SSRF의 신뢰 경계를 각각 한 문장으로 말할 수 있어야 한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 054회차 | 06-06 직접 문제

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 54/80회차 · 기록 묶음 11의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q16

HttpOnly 쿠키 속성의 주요 역할은?

1. 모든 API 권한을 자동 승인

2. DB 파일을 백업

3. 브라우저의 모든 XSS 동작을 완전히 차단

4. 해당 쿠키의 JavaScript 직접 읽기를 제한

내 선택·근거: _____

B06Q17

서명된 일반 JWT payload에 대한 옳은 설명은?

1. 반드시 암호화돼 읽을 수 없다.

2. 디코딩만 하면 신뢰할 수 있다.

3. 읽을 수 있으므로 민감 정보 최소화와 서명·클레임 검증이 필요하다.

4. 만료 시간을 검사할 필요가 없다.

내 선택·근거: _____

B06Q18

서버가 사용자 제공 URL로 요청하면서 내부 시스템 자원에 접근하게 되는 문제와 가장 관련된 것은?

1. SSRF

2. 기능점수

3. 세션의 단순 만료

4. 대칭키 길이

내 선택·근거: _____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 055회차 | 06-06 해설·재현

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 55/80회차 · 기록 묶음 11의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

먼저 직접 푼 뒤 확인합니다.

B06Q16

정답: 4번

HttpOnly는 스크립트의 쿠키 직접 접근을 제한한다. XSS의 요청 실행 등 모든 영향을 없애지 않고 서버 인가 검사도 대체하지 않는다.

B06Q17

정답: 3번

서명과 암호화는 다르다. 해독 가능한 payload와 검증되지 않은 claim을 신뢰하면 안 되며 필요한 만료·발급자·대상 조건을 확인한다.

B06Q18

정답: 1번

서버 측 요청 위조가 핵심이다. 허용 목적지·스킴·네트워크 경계를 검토하며 다른 항목은 이 공격을 정의하지 않는다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 056회차 | 06-06 원리 I

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 56/80회차 · 기록 묶음 12의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

응용 문제: 로그아웃·만료·폐기의 차이

토큰이 사용자 기기에서 삭제되었어도 이미 복사된 토큰이 서버에서 계속 유효할 수 있다. 로그아웃의 요구에 따라 서버 세션 무효화, 토큰 수명, 갱신 토큰 폐기, 별도 폐기 목록 등을 검토한다. 구체적인 방식은 상태를 어디에 관리하는지에 달려 있다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 057회차 | 06-06 원리ㅍ

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 57/80회차 · 기록 묶음 12의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

세션 식별자를 로그인 전과 후에 그대로 유지하는 상황은 공격자가 미리 정한 식별자로 사용자를 유도하는 세션 고정 위험과 연결될 수 있다. 로그인 후 갱신과 이전 식별자 무효화를 적용한다. 세션 탈취는 이미 유효한 식별자를 빼앗는 상황으로 개념을 구분한다. 두 공격이 동시에 가능할 수도 있다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 058회차 | 06-06 예제·적용

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 58/80회차 · 기록 묶음 12의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

강화 API 검증표: 서명·사용 목적·현재 권한

가상 API는 토큰의 서명·허용 알고리즘·발급자·대상 서비스·만료를 검증하고, 사용자 현재 권한과 대상 자료의 소속을 확인한다. 조건 중 하나라도 실패하면 거절한다. 이는 토큰 검증과 객체 인가를 따로 생각하기 위한 연습 규약이다.

손풀이: 서명이 유효해도 대상 서비스가 다르거나 만료됐다면 거절이다. 토큰의 역할이 승인자로 적혀 있어도 서버 정책의 현재 승인 권한이 철회됐다면 승인할 수 없다. 일반 서명 JWT의 payload는 암호화된 비밀 저장소가 아니므로 비밀값을 넣고 숨겨졌다고 생각하지 않는다.

SSRF 가상 규칙은 승인된 외부 호스트만 요청하고 내부 주소·다른 호스트로의 리다이렉트는 거절한다. 처음 URL이 허용 호스트라도 응답이 내부 주소로 이동시킨다면 자동 따라가기는 이 규칙을 깨뜨린다. 리다이렉트를 비활성화하거나 매 단계의 최종 대상도 규칙대로 검증해야 한다. 이름 검사·DNS 결과·네트워크 경계는 서로 다른 확인 단계다. 화면 검증·첫 URL 검사·토큰 서명 중 하나만 맞는 사례를 전체 통과로 확대하지 않는다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 059회차 | 06-06 직접 문제

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 59/80회차 · 기록 묶음 12의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이·서술형 작성
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개와 서술형 1개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q40

가상 토큰 규약은 서명·대상 서비스·만료 조건 모두 통과해야 한다. 서명은 유효하지만 만료됐다. 판정은?

1. 서명만 유효하면 허용

2. 거절

3. payload를 읽을 수 있으므로 허용

4. HTTPS이면 만료가 연장됨

내 선택·근거: _____

B06Q41

가상 승인 API는 현재 권한을 검사한다. 유효한 JWT에 승인자 역할이 있지만 현재 권한은 철회됐다. 처리는?

1. 토큰 발급 시 역할이 우선하므로 허용

2. 현재 권한에 따라 승인을 거절

3. 서명이 있어 인가 검사는 생략

4. payload는 항상 암호화되어 확인 불가

내 선택·근거: _____

B06Q42

가상 URL 규약은 허용 호스트만 요청하며 내부 주소 리다이렉트는 거절한다. 첫 호스트 검사 뒤 내부 주소 이동을 자동으로 따라갔다. 문제는?

1. SQL 주입만 검사하면 해결

2. 최초 호스트가 허용되면 이후 어디든 허용

3. 최초 검사만으로 최종 대상 정책을 지키지 못함

4. 리다이렉트는 서버 요청 대상을 절대 바꾸지 않음

내 선택·근거: _____

W06Q06

가상 API는 서명·대상·만료·현재 권한을 모두 검사한다. 서명은 유효하지만 만료·권한 철회 상태다. URL 규약은 내부 이동 금지인데 첫 호스트 검사 뒤 내부 리다이렉트를 따라간다. 처리와 근거를 쓰라.

조건·원리·중간 과정·결론 순서로 먼저 답안을 작성합니다.

내 답안: _____

_____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 060회차 | 06-06 해설·재현

세션·API·안전한 개발: 인증 뒤의 공격면 점검 · 과목 60/80회차 · 기록 묶음 12의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

서술형 모범답안과 자가 채점 기준

B06Q40

정답: 2번

정답 근거: 만료 조건도 필수이므로 서명 유효만으로 사용할 수 없다.

「서명만 유효하면 허용」- 세 필수 조건이라는 규약을 위반한다.

「payload를 읽을 수 있으므로 허용」- 내용을 해석하는 것과 토큰 사용 가능 여부는 다르다.

「HTTPS이면 만료가 연장됨」- 전송 보호가 토큰 기한을 바꾸지 않는다.

B06Q41

정답: 2번

정답 근거: 토큰에 기록된 과거 역할과 현재 허용 행위를 구분한다.

「토큰 발급 시 역할이 우선하므로 허용」- 현재 권한 검사 규약을 위반한다.

「서명이 있어 인가 검사는 생략」- 토큰 신뢰 검증과 현재 행위의 인가는 별도다.

「payload는 항상 암호화되어 확인 불가」- JWT의 일반 서명과 암호화는 다르며 항상 암호화라는 단정은 틀린다.

B06Q42

정답: 3번

정답 근거: 리다이렉트를 비활성화하거나 각 단계의 실제 대상을 검증해야 한다.

「최초 호스트가 허용되면 이후 어디든 허용」- 내부 주소 이동을 금지한 규약에 어긋난다.

「리다이렉트는 서버 요청 대상을 절대 바꾸지 않음」- 자동으로 따라가면 다른 대상에 요청한다.

「SQL 주입만 검사하면 해결」- URL과 네트워크 대상의 경계는 SQL 입력 경계와 다르다.

W06Q06

가상 API는 서명·대상·만료·현재 권한을 모두 검사한다. 서명은 유효하지만 만료·권한 철회 상태다. URL 규약은 내부 이동 금지인데 첫 호스트 검사 뒤 내부 리다이렉트를 따라간다. 처리와 근거를 쓰라.

모범답안

토큰 만료와 현재 권한 철회가 각각 거절 근거다. 서명 신뢰와 현재 행위 인가는 별도다. 첫 호스트가 허용됐어도 내부 주소로 이동하면 정책을 위반한다. 리다이렉트를 비활성화하거나 각 단계의 실제 대상과 허용 여부를 다시 검증해 금지 대상을 요청하지 않는다.

10점 자가 채점 기준

- 4점: 만료 거절 1점, 권한 철회 거절 1점, 서명 검증과 현재 인가의 구분 2점을 쓴다.
- 3점: 최초 호스트만 검증함 1점, 최종 내부 대상이 정책 위반임 2점을 설명한다.
- 3점: 리다이렉트 차단 또는 각 단계 재검증 2점, 금지 대상 요청을 막는 관찰 기준 1점을 제시한다.

점수는 학습용 자가 채점이며 실제 시험 배점 재현이 아닙니다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 061회차 | 06-07 원리 I

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 61/80회차 · 기록 묶음 13의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

망과 시스템 통제

방화벽은 정책에 따라 통신을 허용·차단한다. IDS는 침입을 탐지하고 경보를 만드는 역할, IPS는 탐지와 함께 차단하는 역할에 초점을 둔다. 배치·구성에 따라 실제 기능이 겹칠 수 있다. WAF는 웹 요청의 공격 패턴과 정책을 다루며 운영체제·DB·애플리케이션 권한의 모든 취약점을 없애지 않는다.

네트워크 분리는 한 구역의 침해가 다른 구역으로 이동하는 영향을 줄인다. 패치 관리에는 자산 식별·취약점 우선순위·시험·배포·재확인이 포함된다. EOL 소프트웨어, 불필요한 서비스, 기본 비밀번호, 과도한 권한은 운영 공격면을 넓힌다. 안전한 설정 기준과 예외 기록도 관리한다.

로그와 경보

로그에는 시각·주체·대상·행동·결과·관련 식별자 등이 필요할 수 있다. 시스템의 시각이 맞지 않으면 사건 순서를 분석하기 어렵다. 중앙 수집과 접근통제·무결성 보호·보관 정책을 고려한다. 로그에 평문 비밀번호·불필요한 고객 원문을 남기는 것은 추적성을 높이기보다 새로운 유출 위험을 만든다.

탐지 결과의 TP는 실제 공격을 공격으로 탐지, FP는 정상 동작을 공격으로 오탐, FN은 실제 공격을 놓친 것, TN은 정상 동작을 정상으로 처리한 것이다. 보안 탐지에도 정밀도와 재현율의 관점이 유용하다. 오탐을 줄이려 임계값을 바꾸면 미탐이 늘 수 있어 업무 비용을 함께 본다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

보완 B06 → 118쪽

정보보안 062회차 | 06-07 원리ㅍ

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 62/80회차 · 기록 묶음 13의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

계산 예제

탐지된 경보 50건 중 실제 공격이 30건이고 실제 공격 전체가 40건이었다. TP=30, FP=20, FN=10이다. 정밀도는 30/50=60%, 재현율은 30/40=75%다. 정밀도 60%는 전체 요청의 60%가 공격이라는 뜻이 아니다. 모수가 무엇인지 구분한다. 전체 정상 건수는 주어지지 않았으므로 정확도는 여기서 계산할 수 없다.

백업·RPO·RTO

RPO는 복구 시 허용 가능한 데이터 손실의 시간 범위와 관련된다. RTO는 중단 후 복구까지 목표로 하는 시간과 관련된다. 백업 주기만 정했다고 RTO가 만족되는 것은 아니다. 파일을 읽고 DB를 복원하고 무결성과 업무를 확인하는 시간이 필요하다.

가상 상황에서 마지막 유효 백업은 02:00, 장애는 04:30에 발생했다. 다른 로그 복구가 없다면 데이터 손실 시간은 2시간 30분이다. RPO가 1시간이면 만족하지 못한다. 실제 업무 복구가 06:00이면 장애 후 복구 시간은 1시간 30분이고 RTO가 2시간이면 시간 조건은 만족한다. "백업 완료 시각"과 "사용 가능한 복구 시점"은 다를 수 있어 문제 조건을 확인한다.

랜섬웨어 대비에서는 주 시스템과 같은 계정·같은 저장소에만 백업을 두면 함께 손상될 수 있다. 분리·불변 보관, 권한 통제, 정기 복구 시험이 중요하다. 백업 파일이 있다는 사실은 복원 가능성의 증명이 아니다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 063회차 | 06-07 예제·적용

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 63/80회차 · 기록 묶음 13의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

사고 대응의 흐름

사전에 역할·연락 경로·증거 보호·복구 기준을 준비한다. 사고를 발견하면 영향과 신뢰도를 평가하고 피해 확산을 억제하며 원인을 제거하고 복구·재발 방지를 수행한다. 프레임워크마다 단계 명칭과 묶음이 다를 수 있으므로 이 교재의 흐름을 특정 최신 표준의 고정 단계명으로 암기하지 않는다. 증거를 지워 원인 분석을 막지 않도록 조치와 시각을 기록한다.

자가 연습과 풀이

운영 서버를 바로 재설치하면 서비스는 빨리 돌아올 수 있으나 필요한 증거가 사라질 수 있다. 업무 복구와 증거 보존을 상황·정책에 따라 함께 판단한다. 권한 없는 대응자가 민감 로그를 개인 기기로 복사하는 행동은 별도의 위험이 된다.

완료 기준

IDS·IPS·WAF의 주된 역할을 구분하고 정밀도·재현율·RPO·RTO를 직접 계산할 수 있어야 한다. 복구 시험의 성공 기준을 업무 관점으로 적어보자.

응용 계산: 목표와 실제 복구를 분리하기

RTO2시간은 목표이며 백업 작업의 실행 간격2시간이라는 뜻이 아니다. RPO30분이면 복구 가능한 데이터 시점이 장애30분 이전보다 오래되지 않도록 설계해야 한다. 야간 전체 백업만으로 만족하지 못하면 로그·증분 복구 같은 방법과 검증을 검토한다.

복구 시험에서 파일 복원40분,DB 적용25분,업무 확인20분이 순차라면 총85분이다. RTO60분이면 파일만 복원한40분으로 통과라고 판단할 수 없다. 병렬 가능 여부가 명시되면 경로 기준으로 계산하지만, 조건 없이 동시에 실행된다고 가정하지 않는다. 업무 확인은 데이터와 서비스의 실제 사용 가능성을 검증한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 064회차 | 06-07 직접 문제

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 64/80회차 · 기록 묶음 13의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q19

경보 50건 중 실제 공격 30건, 실제 공격 전체 40건이다. 정밀도와 재현율은?

1. 75%,60%

2. 60%,60%

3. 60%,75%

4. 30%,40%

내 선택·근거: _____

B06Q20

마지막 복구 가능한 시점 02:00, 장애 04:30, 업무 복구 06:00이다. 다른 복구 수단이 없을 때 손실 시간과 복구 시간은?

1. 2시간30분,1시간30분

2. 1시간30분,2시간30분

3. 4시간,6시간

4. 0분,0분

내 선택·근거: _____

B06Q21

백업 운영에 대한 가장 적절한 설명은?

1. 백업 파일 존재만으로 즉시 복구가 보장된다.

2. 복구 시험·분리 보관·권한 통제도 중요하다.

3. 운영 계정과 저장소에만 백업을 두면 모든 랜섬웨어가 차단된다.

4. 로그에는 비밀번호 원문이 반드시 필요하다.

내 선택·근거: _____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 065회차 | 06-07 해설·재현

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 65/80회차 · 기록 묶음 13의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

먼저 직접 푼 뒤 확인합니다.

B06Q19

정답: 3번

정밀도=TP/(TP+FP)=30/50,재현율=TP/(TP+FN)=30/40이다. 전체 정상 수가 없어 정확도는 별도로 계산할 수 없다.

B06Q20

정답: 1번

손실은 04:30-02:00=2시간30분,복구는 06:00-04:30=1시간30분이다. RPO와 RTO의 시간 기준이 다르다.

B06Q21

정답: 2번

복원 가능성과 안전한 접근을 검증해야 한다. 같은 계정·저장소의 백업은 함께 피해를 입을 수 있고 비밀번호 원문은 불필요한 유출 위험이다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 066회차 | 06-07 원리 I

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 66/80회차 · 기록 묶음 14의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

강화 복구 손풀이: 마지막 파일과 마지막 복원점

가상 백업은 10:00 전체,11:00 증분이 유효하고 12:00 증분은 손상됐다. 다른 복구 수단은 없으며 14:20 장애 후 15:10 업무를 복구했다. 따라서 마지막 실제 복원점은 11:00, 손실 구간은 3시간 20분=200분, 장애부터 복구는 50분이다. 12:00 파일이 존재한다는 이유로 마지막 복원점을 12:00로 보고하지 않는다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 067회차 | 06-07 원리ㅍ

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 67/80회차 · 기록 묶음 14의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

복원 시험은 원본과 다른 격리 환경에서 필요한 키·설정·연계까지 준비해 자료 일치·핵심 거래·접근 권한을 확인한다. 침해된 운영 계정이 백업도 삭제할 수 있는 반례를 고려해 백업 접근 경계를 분리한다. 성공 알림은 실제 복원의 증거가 아니다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 068회차 | 06-07 예제·적용

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 68/80회차 · 기록 묶음 14의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

탐지 표도 분모부터 세자. 전체 1,000건 중 경보 80건, 실제 공격 25건, 경보 중 실제 공격 20건이면 TP 20,FP 60,FN 5,TN 915다. 정밀도 20/80=25%,재현율 20/25=80%다. 오탐 60건의 검토 부담과 누락 5건의 위험을 함께 본다. 경보를 많이 내는 것과 좋은 탐지는 같은 뜻이 아니다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 069회차 | 06-07 직접 문제

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 69/80회차 · 기록 묶음 14의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이·서술형 작성
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개와 서술형 1개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q43

10:00 전체·11:00 증분은 유효, 12:00 증분은 손상이며 다른 복구 수단은 없다. 14:20 장애·15:10 복구 때 실제 자료 손실 구간과 복구 소요 시간은?

1. 200분·200분

2. 50분·200분

3. 140분·50분

4. 200분·50분

내 선택·근거: _____

B06Q44

전체 1,000건·경보 80건·실제 공격 25건·경보 중 실제 공격 20건이다. 정밀도와 재현율은?

1. 80%·25%

2. 2%·8%

3. 100%·100%

4. 25%·80%

내 선택·근거: _____

B06Q45

백업 파일이 있지만 침해된 운영 계정이 백업도 삭제할 수 있다. 적절한 개선 방향은?

1. 파일 이름만 보관용으로 변경

2. 성공 알림만 보고 복원 생략

3. 백업 접근 경계 분리와 격리 복원 시험

4. 운영 계정 권한을 더 확대

내 선택·근거: _____

W06Q07

유효 복원점 11:00, 손상 백업 12:00, 장애 14:20, 복구 15:10이다. 손실·복구 시간과 경보 80건/실제 공격 25건/TP20건의 정밀도·재현율 및 복원 시험을 쓰라.

조건·원리·중간 과정·결론 순서로 먼저 답안을 작성합니다.

내 답안: _____

_____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 070회차 | 06-07 해설·재현

운영 보안·탐지·백업: 침해를 발견하고 복구하기 · 과목 70/80회차 · 기록 묶음 14의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

서술형 모범답안과 자가 채점 기준

B06Q43

정답: 4번

정답 근거: 최신 유효 복원점 11:00부터 장애 14:20까지 200분, 장애부터 복구까지 50분이다.

「140분·50분」 - 손상된 12:00 백업을 유효 복원점으로 사용했다.

「200분·200분」 - 자료 손실 구간과 장애 후 복구 소요 시간을 혼동했다.

「50분·200분」 - 두 지표의 의미와 순서를 뒤집었다.

B06Q44

정답: 4번

정답 근거: 정밀도=20/80=25%, 재현율=20/25=80%다.

「80%·25%」 - 경보와 실제 공격의 분모를 뒤집었다.

「2%·8%」 - 전체 1,000을 분모로 사용한 비율은 해당 두 지표가 아니다.

「100%·100%」 - FP60과 FN5가 있으므로 두 지표가 모두 100%일 수 없다.

B06Q45

정답: 3번

정답 근거: 백업의 존재·보호·실제 사용 가능성을 따로 검증한다.

「파일 이름만 보관용으로 변경」 - 권한과 복원 가능성은 바뀌지 않는다.

「성공 알림만 보고 복원 생략」 - 실제 자료·설정·키가 복원된다는 실행 증거가 없다.

「운영 계정 권한을 더 확대」 - 침해 계정으로 운영과 백업을 동시에 훼손할 위험을 늘릴 수 있다.

W06Q07

유효 복원점 11:00, 손상 백업 12:00, 장애 14:20, 복구 15:10이다. 손실·복구 시간과 경보 80건/실제 공격 25건/TP20건의 정밀도·재현율 및 복원 시험을 쓰라.

모범답안

자료 손실 구간은 11:00~14:20의 200분, 장애 후 복구는 50분이다. 손상된 12:00 백업은 복원점으로 쓸 수 없다. 정밀도20/80=25%, 재현율20/25=80%다. 격리 환경에서 자료·키·설정·핵심 거래·권한을 확인하고 운영 침해 계정과 백업 삭제 권한의 경계를 분리한다.

10점 자가 채점 기준

- 3점: 손실 200분 1점, 복구 50분 1점, 손상 백업 제외 1점을 쓴다.
- 3점: 정밀도 식과 25% 1점, 재현율 식과 80% 1점, 경보/실제 공격 분모 구분 1점을 계산한다.
- 4점: 격리 복원 조건 1점, 확인 항목 두 가지 각각 1점, 백업 훼손 권한 경계 분리 1점을 제시한다.

점수는 학습용 자가 채점이며 실제 시험 배점 재현이 아닙니다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 071회차 | 06-08 원리 I

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 71/80회차 · 기록 묶음 15의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

개인정보 보호의 학습 범위

개인정보는 정보의 내용·결합 가능성·처리 맥락에 따라 개인을 식별하거나 관련될 수 있는 정보다. 가명처리는 식별에 필요한 추가 정보와의 연결을 분리하는 접근이고, 익명처리는 더 이상 개인을 식별할 수 없게 처리하는 목표와 관련된다. 단순히 이름 한 열을 지웠다고 익명성이 보장되지 않는다. 재식별 위험은 다른 자료와의 결합을 고려해야 한다.

이 교재는 법률 자문이나 최신 조문 정리집이 아니다. 법률의 수집 근거·보유 기간·통지 의무·제재 금액은 개정될 수 있으므로 응시 공고의 기준일과 국가법령정보센터·개인정보보호위원회의 최신 원문을 확인한다. 날짜나 벌칙 금액을 확인 없이 확정된 시험 사실처럼 넣지 않는다. 여기서는 최소 수집·목적 제한·보관/삭제·권한 분리·가명정보 추가정보 보호 같은 기초 원리를 익힌다.

데이터 생명주기의 보안

수집에서는 필요한 항목과 목적을 정하고, 저장에서는 암호화·권한·복구를 검토하며, 이용에서는 업무에 필요한 범위만 사용한다. 공유에서는 받는 주체·목적·방식·기록을 확인하고, 폐기에서는 원본·복제·백업·출력물의 수명과 삭제 정책을 함께 검토한다. 암호화만 하면 수집 목적이나 사용 권한의 문제까지 자동으로 해결되지는 않는다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 072회차 | 06-08 원리ㅍ

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 72/80회차 · 기록 묶음 15의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

운영·개발·분석 환경의 분리는 중요하다. 실제 고객 데이터를 테스트 PC로 복사하지 않아도 되는 합성 데이터나 적절한 보호 자료를 우선 검토한다. 해시만 적용한 식별자가 원래 사람과 쉽게 연결되면 보호 수준을 과대평가하면 안 된다. 해시의 일방향성과 개인정보의 식별 가능성은 별개의 질문이다.

단계별 종합 사례

신청서 분석 파일에는 신청번호·성명·연락처·심사결과가 있다. 통계 보고서에는 성명·연락처가 필요하지 않다. 첫 단계는 수집·이용 목적에 맞지 않는 항목을 분석 자료에서 줄이는 것이다. 두 번째는 신청번호를 분석용 식별자로 대체하고 연결 정보는 별도 권한 아래 관리한다. 세 번째는 소규모 집단의 공개 통계가 특정인을 유추하게 하는지 확인한다. 네 번째는 결과 파일의 접근·보관·삭제를 관리한다.

지역·직업·나이의 조합이 자료에서 단 한 명이라면 이름을 제거해도 다른 자료와 결합해 추정될 수 있다. 모든 집단이 k명 이상이 되도록 하는 k-익명성 개념은 이런 단일성 위험을 줄이는 접근이지만 민감 속성의 다양성 부족이나 외부 배경지식 등 모든 문제를 해결하지 않는다. 시험에서 k-익명성을 묻더라도 "절대 재식별 불가능"이라는 선택지는 경계한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 073회차 | 06-08 예제·적용

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 73/80회차 · 기록 묶음 15의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

표를 읽는 숫자 예제

공개 표의 연령대·지역 조합별 인원이 3, 5, 7명이다. 이 두 항목을 준식별자로 본 단순 k-익명성 확인에서는 가장 작은 집단이 3명이므로 k=3이다. 목표 k=5라면 첫 집단은 합치기·일반화·억제 등의 재설계를 검토한다. 이 계산은 해당 조합으로 정의한 집단 크기만 확인하는 예제이며 실제 안전성을 완전히 증명하지 않는다.

보안 문제를 푸는 순서

먼저 무엇을 보호하는지 정한다. 다음에 위협이 넘어오는 경계와 취약점을 찾는다. 이어 통제가 공격의 어떤 조건을 끊는지 확인한다. 마지막으로 남는 위험과 운영 조건을 확인한다. "암호화니까 모든 문제 해결", "로그인했으니까 모든 권한 허용", "백업 있으니까 즉시 복구"처럼 통제 하나를 전체 안전성으로 확대하는 선택지는 틀리기 쉽다.

자가 연습과 풀이

팀이 고객 전화번호를 해시해 테스트 자료에 썼다. 번호의 가능한 값이 제한되어 공격자가 후보를 대입할 수 있고 다른 정보와 연결될 수도 있다. 단순 해시를 무조건 익명처리라고 단정할 수 없다. 목적에 맞는 합성 자료·가명 처리·접근 통제와 재식별 위험 검토를 함께 고려한다.

완료 기준

가명·익명·암호화를 구분하고 최소 수집과 환경 분리를 설명할 수 있어야 한다. 법률 숫자는 원문에서 확인하고, 종합 사례의 자산·취약점·예방·탐지·복구를 한 장에 정리해보자.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 074회차 | 06-08 직접 문제

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 74/80회차 · 기록 묶음 15의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q22

이름을 지운 분석 자료의 익명성에 대한 옳은 설명은?

1. 이름만 없으면 항상 익명이다.

2. 다른 속성·외부 자료와 결합한 식별 가능성을 검토해야 한다.

3. 해시는 모든 개인정보 규정을 면제한다.

4. 암호화하면 목적 제한이 없어졌다.

내 선택·근거: _____

B06Q23

준식별자 조합별 집단 크기가 3,5,7일 때 단순 k-익명성 계산의 k는?

1. 5

2. 7

3. 15

4. 3

내 선택·근거: _____

B06Q24

최신 개인정보 법률의 통지 기한·제재 금액을 공부할 때 적절한 방법은?

1. 연도 없는 블로그 숫자를 그대로 고정 암기

2. 본 교재의 가상 계산값을 실제 법으로 사용

3. 키 공간 공식만 적용

4. 공고 기준일과 최신 국가법령정보센터·주무 기관 원문을 확인

내 선택·근거: _____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 075회차 | 06-08 해설·재현

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 75/80회차 · 기록 묶음 15의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

먼저 직접 푼 뒤 확인합니다.

B06Q22

정답: 2번

재식별 가능성은 결합·맥락에 달려 있다. 이름 제거·단순 해시·암호화가 모든 보호 의무나 목적 문제를 자동 해결하지 않는다.

B06Q23

정답: 4번

모든 집단이 최소 k명 이상이어야 하므로 최솟값 3이다. 평균이나 합계가 아니며 이 계산이 절대 재식별 불가능성을 보장하지는 않는다.

B06Q24

정답: 4번

법률 수치는 개정·적용 조건이 중요하므로 공식 원문과 기준일을 확인한다. 가상 예제나 일반 보안 원리는 법 조문의 숫자를 대신하지 않는다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

정보보안 076회차 | 06-08 원리 I

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 76/80회차 · 기록 묶음 16의1/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 앞부분 읽기·용어·조건 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

응용 문제: 가명처리와 공개 범위

분석용 식별자로 바꾼 자료라도 연결 정보를 가진 조직은 다시 연결할 수 있다. 그러므로 가명처리를 익명처리와 같다고 보지 않는다. 연결 정보 분리·권한 제한·이용 목적·재식별 위험을 함께 관리한다. 암호화는 적절한 키를 가진 주체가 복호화할 수 있는 보호 수단이다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 077회차 | 06-08 원리ㅍ

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 77/80회차 · 기록 묶음 16의2/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	본문 가운데 부분 읽기·차이·경계 설명
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

소규모 집단의 평균 금액과 인원1이 공개되면 평균 자체가 그 한 사람의 금액일 수 있다. 직접 식별자를 지워도 집계 결과의 공개 위험을 검토해야 한다. 개인정보 문제는 이름·전화번호 열만 보는 체크리스트를 넘어 결합·표본 크기·접근자·사용 목적의 관계로 판단한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 078회차 | 06-08 예제·적용

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 78/80회차 · 기록 묶음 16의3/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	남은 본문·예제의 중간 상태 손추적
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

강화 가상 자료 공개: 작은 집단과 다른 속성

준식별자 조합별 집단이 A 3명·B 4명·C 5명이고 각 집단의 민감 속성 서로 다른 값 수가 1·2·2라고 하자. 단순 k-익명성의 k는 최솟값 3이다. 그러나 A집단의 민감 속성이 모두 같다면 집단 구성원에게 그 속성을 추정할 수 있어 k만으로 모든 민감 정보 추론을 막는다고 단정할 수 없다.

가상 공개 기준이 '각 집단 3명 이상 AND 민감 속성 서로 다른 값 2개 이상'이면 A집단은 실패한다. 이름 삭제만으로 공개 승인하지 않고 목적·필요 항목·재식별 가능성·외부 결합 자료·접근 범위를 함께 검토한다. 집단을 일반화·억제하면 유용성과 위험이 함께 변할 수 있으므로 다시 계산한다.

손풀이: 분석 목적이 월별 승인 비율이면 원문 자유기입란과 연락처가 꼭 필요한지 먼저 묻는다. 가상 규약에서 필요 항목을 월·상태·집계값으로 제한했다면 나머지를 제외하고 원본은 승인된 별도 경로에 보호한다. 이 기준은 실제 개인정보 법률의 면책·보관기간·통지기간을 뜻하지 않는다. 법의 구체 수치는 최신 적용 조건과 공식 원문을 별도로 확인한다.

오늘 완료 기준

오늘 실제 읽은 절의 용어·조건을 자기 말로 설명하고 해당 예제의 중간 상태를 적습니다. 아직 읽지 못한 절은 다음 시작점으로 남깁니다.

정보보안 079회차 | 06-08 직접 문제

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 79/80회차 · 기록 묶음 16의4/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	지정 문제 독립 풀이·서술형 작성
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

오늘 지정 범위: 객관식 3개와 서술형 1개.

정답 페이지를 펼치기 전에 내 선택·근거와 중간 계산을 적습니다.

B06Q46

전체 준식별자 조합에 따른 동질 집단의 크기가 3·4·5이다. 모든 집단에 보장되는 단순 k-익명성의 최대 k는?

1. 12

2. 3

3. 4

4. 5

내 선택·근거: _____

B06Q47

가상 공개 조건은 각 집단 3명 이상 AND 민감 속성의 서로 다른 값 2개 이상이다. A 집단은 3명·서로 다른 값 1개이다. 판정은?

1. 민감 속성 조건 미충족으로 실패

2. 전체 12명이므로 통과

3. 이름 삭제만 하면 자동 통과

4. 집단 3명이므로 통과

내 선택·근거: _____

B06Q48

가상 월별 승인 비율 분석에는 월·상태·집계값만 필요하다고 정했다. 적절한 자료 처리는?

1. 연락처와 자유 기입 원문도 항상 배포

2. 필요 항목으로 제한하고 원본은 승인된 별도 경로에 보호

3. 이름을 지웠으므로 모든 위험 없음

4. 이 연습 기준을 법률 면책으로 선언

내 선택·근거: _____

W06Q08

준식별자 집단 A·B·C의 크기는 3·4·5, 민감 속성 서로 다른 값 수는 1·2·2다. 가상 조건은 집단별 3명 이상 AND 서로 다른 값 2개 이상이다. 최대 k와 공개 판정·학습 한계를 설명하라.

조건·원리·중간 과정·결론 순서로 먼저 답안을 작성합니다.

내 답안: _____

_____

오늘 완료 기준

내 선택과 조건·근거를 먼저 남깁니다. 정답은 바로 다음 별도30분 회차에서 확인합니다. 서술형이 있으면 초안·식·결론을 먼저 적습니다.

정보보안 080회차 | 06-08 해설·재현

개인정보·안전한 데이터 처리와 종합 문제 풀이 · 과목 80/80회차 · 기록 묶음 16의5/5단계

분	할 일
3	앞선 개념 또는 첫 오류 한 가지를 답 없이 회상
25	분리 해설 비교·자가 채점·답 없는 재풀이
2	실제 공부 분·첫 오류·다음 시작점 기록

30분에 멈춥니다. 지정 내용이 남으면 다음 학습일에 같은 회차를 이어갑니다. 아래 자료의 쪽수가 하루에 반드시 끝낼 분량을 뜻하지 않습니다.

오늘 자료

서술형 모범답안과 자가 채점 기준

B06Q46

정답: 2번

정답 근거: 가장 작은 집단 크기가 3이므로 모든 집단에 보장되는 최대 k는 3이다.

「4」 - 크기 3의 집단이 있어 모든 집단에 4를 보장하지 못한다.

「5」 - 크기 3과 4의 집단이 있어 5를 보장하지 못한다.

「12」 - 전체 인원 합은 집단별 최소 크기가 아니다.

B06Q47

정답: 1번

정답 근거: 집단 크기는 통과하지만 민감 속성 다양성 조건은 실패한다.

「집단 3명이므로 통과」 - 필수 조건 두 개를 모두 만족해야 한다.

「전체 12명이므로 통과」 - 집단별 검사를 전체 인원 합으로 대신할 수 없다.

「이름 삭제만 하면 자동 통과」 - 이름 삭제에 관한 예외는 가상 규약에 없다.

B06Q48

정답: 2번

정답 근거: 목적·최소 필요 범위·권한·재식별 위험을 함께 확인한다.

「연락처와 자유 기입 원문도 항상 배포」 - 목적에 불필요한 정보 노출을 늘린다.

「이름을 지웠으므로 모든 위험 없음」 - 다른 준식별자와 외부 자료 결합 위험이 남을 수 있다.

「이 연습 기준을 법률 면책으로 선언」 - 가상 연습 기준은 실제 법률이나 면책을 대신하지 않는다.

W06Q08

준식별자 집단 A·B·C의 크기는 3·4·5, 민감 속성 서로 다른 값 수는 1·2·2다. 가상 조건은 집단별 3명 이상 AND 서로 다른 값 2개 이상이다. 최대 k와 공개 판정·학습 한계를 설명하라.

모범답안

모든 집단의 최소 크기가 3이므로 최대 k는 3이다. A는 서로 다른 민감 값이 1개라 가상 공개 조건에 실패하고 B·C는 두 조건을 만족한다. 이름 삭제나 집단 크기만으로 민감 속성 추론 위험이 없어지지 않는다. 목적에 필요한 항목·외부 결합·권한을 검토한다. 가상 기준은 법률 면책이나 실제 보관기한을 대신하지 않는다.

10점 자가 채점 기준

- 3점: 최소 집단 크기 정의 1점, 최대 k=3과 그 근거 2점을 쓴다.
- 4점: A의 다양성 실패 2점, B·C 통과 1점, 동일 민감 값의 추론 한계 1점을 설명한다.
- 3점: 목적/결합/권한 중 두 가지 검토 2점, 가상 조건과 실제 법의 구분 1점을 쓴다.

점수는 학습용 자가 채점이며 실제 시험 배점 재현이 아닙니다.

오늘 완료 기준

첫 오류의 조건을 적고 답을 닫아 재현합니다. 서술형은 모범답안과10점 자가 채점 근거도 남깁니다. 남은 부분이 있으면 같은 회차로 이어갑니다.

근거·범위·검증 상태

현재 GI 장별 교재와 과목별 문제·해설·서술형을 바탕으로 구성했습니다. 기관 공고 범위의 기존 확인 기준은2026-10-04, 이번 PDF 구성일은2026-10-11입니다. 다음 지원 시 새 공식 안내를 다시 확인합니다.

- NIST Glossary - Least Privilege
- OWASP Authentication Cheat Sheet
- OWASP Password Storage Cheat Sheet
- OWASP SQL Injection Prevention Cheat Sheet
- OWASP Cross Site Scripting Prevention Cheat Sheet
- OWASP CSRF Prevention Cheat Sheet
- OWASP Session Management Cheat Sheet
- RFC 8446 - TLS 1.3
- NIST Incident Response Recommendations SP 800-61 Rev.3
- 개인정보보호위원회 - 최신 공식 안내 확인
- 국가법령정보센터 - 개인정보 관련 최신 법령 확인
- IBK 채용 FAQ
- 기술보증기금 2026 상세 출제범위
- OWASP Authorization Cheat Sheet - 매 요청 인가·기본 거절
- OWASP Cryptographic Storage Cheat Sheet - 암호 모드와 인증
- OWASP Key Management Cheat Sheet - DEK/KEK와 이행
- OWASP SSRF Prevention Cheat Sheet - 대상 검증·리다이렉트
- NIST SP800-38D - GCM IV 유일성 조건

핵심 보완 찾아보기

원래 회차와 문제 순서는 그대로 따라갑니다. 아래 보완 자료는 해당 개념이 헷갈리는 날의 학습 25분 안에서 본문과 바꾸어 읽습니다. 추가 과제로 더하지 않습니다.

노란색은 정의·공식·판단 조건입니다. 「헷갈리는 지점」은 혼동하기 쉬운 경계를 설명합니다. 강조 개수는 출제 빈도나 배점을 뜻하지 않습니다.

B01. 비밀번호 저장: salt·작업 비용·pepper의 서로 다른 역할

021~030회차 · 06-03 | 본문 34쪽 → 보완 자료의 같은 번호

B02. 암호화·MAC·서명: 보호 목적을 조합하기

021~030회차 · 06-03 | 본문 33쪽 → 보완 자료의 같은 번호

B03. 인가 결정표: 역할·객체·행동·상태를 함께 검사

011~020회차 · 06-02 | 본문 20쪽 → 보완 자료의 같은 번호

B04. SQL 주입·XSS·CSRF: 같은 입력의 서로 다른 경계

041~050회차 · 06-05 | 본문 59쪽 → 보완 자료의 같은 번호

B05. TLS: 인증서 확인과 업무 인가를 구분하기

031~040회차 · 06-04 | 본문 46쪽 → 보완 자료의 같은 번호

B06. 복구목표: 백업간격·실제복원점·RPO·RTO

061~070회차 · 06-07 | 본문 85쪽 → 보완 자료의 같은 번호

정답·해설은 보완 문제 뒤의 별도 절에서 확인합니다. PDF 책갈피의 「핵심 보완」에서 각 주제로 바로 이동할 수 있습니다.

B01. 비밀번호 저장: salt·작업 비용·pepper의 서로 다른 역할

연결: 021~030회차 · 06-03 | 본문 34쪽

salt는 같은 비밀번호의 저장값을 사용자별로 다르게 하고, KDF 작업 비용은 후보 하나를 검증하는 계산 부담을 높인다.

원리와 판단 조건

비밀번호를 복호화할 수 있게 보관하는 모델과, 입력한 후보를 같은 절차로 계산해 검증하는 모델을 구분한다. 일반적으로 salt와 알고리즘·비용 정보는 해시 옆에 저장할 수 있다.

pepper는 데이터베이스와 분리해 보호하는 비밀이다. salt가 공개되어도 각 salt로 후보를 다시 계산하게 하지만 약한 비밀번호를 강하게 바꾸지는 않는다. KDF 비용은 서버의 로그인 지연·자원과 함께 조정한다.

적용·손풀이

두 사용자가 같은 비밀번호라도 서로 다른 salt s1,s2로 KDF(p,s1),KDF(p,s2)를 저장하면 저장값이 같지 않도록 한다. DB를 얻은 공격자는 각 계정의 salt를 알고 오프라인 후보 계산을 할 수 있다. salt는 침해 후 추측 자체를 불가능하게 하는 장치가 아니다.

헷갈리는 지점

로그인 요청 제한은 온라인 추측을 늦추지만 유출 DB의 오프라인 공격에는 직접 적용되지 않는다. 빠른 SHA-256을 한 번 적용했다고 전용 비밀번호 저장 설계를 대신하지 않는다.

직접 확인

사용자별 salt를 주었으니 공통 salt보다 안전하고, 따라서 약한123456 비밀번호의 추측도 불가능해졌다는 결론은 맞는가?

참고: OWASP · Password Storage (cheatsheetseries.owasp.org)

참고: NIST SP 800-63B-4 (csrc.nist.gov)

B02. 암호화·MAC·서명: 보호 목적을 조합하기

연결: 021~030회차 · 06-03 | 본문 33쪽

읽지 못하게 숨김, 공유키로 변조 확인, 공개키로 서명자 검증은 서로 다른 보장이다.

원리와 판단 조건

암호화는 기밀성 목적, MAC은 공유 비밀을 가진 쪽의 메시지 인증·무결성 검증 목적, 전자서명은 대응 공개키로 검증하는 목적을 갖는다. 비키 해시는 자체로 발신자를 인증하지 않는다.

서명은 서명 대상과 검증키의 신뢰가 중요하다. 검증 성공만으로 숨김·개인키의 비유출·내용의 업무상 진실성까지 증명하지 않는다. MAC은 검증자도 같은 공유키로 새 MAC을 만들 수 있다.

적용·손풀이

승인 결과 파일을 비밀로 보내면서 수신자가 발신 서명까지 확인해야 한다. 검증된 프로토콜에서 발신자 서명과 수신자에게만 열리는 암호화 보호를 함께 설계한다. 학습상 역할은 분리하되 서명·암호화 순서와 포맷을 임의로 만들어 구현하지 않는다.

헷갈리는 지점

개인키 암호화=서명이라는 암기법은 ECDSA·EdDSA 등 서명 구조를 설명하지 못한다. 파일 옆의 SHA-256만 두면 둘을 함께 바꾸는 공격에 대한 신뢰 기준이 없다.

직접 확인

A와B만 공유키를 가진 MAC 메시지가 유효하다. 이것만으로 제3자에게 A만 만들었다고 증명할 수 있는가?

참고: OSTEP · Cryptography (pages.cs.wisc.edu)

B03. 인가 결정표: 역할·객체·행동·상태를 함께 검사

연결: 011~020회차 · 06-02 | 본문 20쪽

인증은 신원 확인, 인가는 특정 자원의 특정 행동 허용 여부다. 로그인과 역할만으로 모든 객체 접근을 허용하지 않는다.

원리와 판단 조건

요청 주체, 행동, 대상 객체, 환경·상태를 입력으로 정책을 평가하고 명시되지 않은 경우 거부한다. 객체 식별자를 복잡하게 만들더라도 서버 권한 검사를 생략할 수 없다.

정책이 승인자 AND 동일 지역 AND 본인 작성 아님 AND 상태 제출완료라면 네 조건을 모두 확인한다. 역할이 회수된 뒤 오래된 토큰·화면이 허용 근거로 남는 경로도 확인한다.

적용·손풀이

부산 승인자 U가 부산 요청 R을 승인하려 한다. R은 U가 만든 요청이고 상태는 제출완료다. 역할·지역·상태가 맞아도 자기 작성 금지 조건이 거짓이라 거부한다. 읽기 권한과 승인 권한을 별도로 정의하면 읽기는 가능하고 승인은 거부될 수도 있다.

헷갈리는 지점

화면 버튼 숨김, URL 난독화, TLS 암호화, CSRF 검증 중 어느 하나도 대상 객체의 업무 인가를 대신하지 않는다.

직접 확인

지역이 다른 감사자는 모든 지역 읽기 허용, 승인 금지다. 부산 자료를 조회한 뒤 승인 API를 호출하면 두 결과는?

참고: OWASP · Authorization (cheatsheetseries.owasp.org)

B04. SQL 주입·XSS·CSRF: 같은 입력의 서로 다른 경계

연결: 041~050회차 · 06-05 | 본문 59쪽

SQL 값은 파라미터로, 화면 출력은 문맥에 맞게, 상태 변경 요청은 권한·요청 진위로 보호한다. 한 방어가 다른 방어를 대체하지 않는다.

원리와 판단 조건

SQL 주입은 신뢰하지 않은 값이 SQL 문법으로 해석되는 경계 문제다. 바인딩 값은 데이터로 처리하며 동적 테이블명·정렬 방향 같은 문법 요소는 허용 목록으로 선택한다.

XSS는 출력 위치의 HTML·속성·JavaScript·URL 문맥을 구분한다. CSRF는 브라우저가 자동 첨부하는 인증 정보로 원치 않은 상태 변경을 일으키는 경로다. 서버 측 권한 검사도 별도로 필요하다.

적용·손풀이

조회 키워드는 WHERE name=@name으로 값 바인딩한다. 정렬 열은 사용자 문자열을 그대로 이어 붙이지 않고 name/date 허용 목록에서 코드가 선택한다. 결과 이름은 안전한 텍스트 출력으로 표시한다. 승인 POST는 대상 인가와 CSRF 방어를 함께 확인한다.

헷갈리는 지점

HttpOnly는 쿠키를 JavaScript로 직접 읽는 경로를 줄이지만 XSS가 같은 사이트 요청을 실행하는 모든 경로를 막지 않는다. CORS를 설정했다고 CSRF와 객체 인가가 자동 해결되지 않는다.

직접 확인

DB 조회가 모두 파라미터화되어 있으면 조회 결과의 고객명을 HTML로 그대로 출력해도 안전한가?

참고: OWASP · SQL Injection Prevention (cheatsheetseries.owasp.org)

참고: OWASP · XSS Prevention (cheatsheetseries.owasp.org)

참고: OWASP · CSRF Prevention (cheatsheetseries.owasp.org)

B05. TLS: 인증서 확인과 업무 인가를 구분하기

연결: 031~040회차 · 06-04 | 본문 46쪽

암호화 연결이 생겨도 상대 신뢰 검증과 업무 권한 검사가 각각 필요하다. TLS 1.3을 옛 RSA 키전송 그림으로 일반화하지 않는다.

원리와 판단 조건

일반 웹 TLS에서는 서버 인증서의 신뢰 경로·호스트명·유효 조건 등을 확인한다. 서버 인증이 사용자 계정 인증이나 특정 신청서 수정 권한을 자동 부여하지 않는다.

키 합의로 트래픽 비밀을 만들고 실제 데이터에는 대칭키 기반 인증 암호화를 사용한다. 전방향 안전성은 임시 키 교환·비밀 폐기 등의 조건 아래 장기 키 노출이 과거 세션 복호로 곧바로 이어지지 않게 하는 성질이다.

적용·손풀이

서비스 이름은 api.example인데 인증서가 other.example용이면 발급자 서명이 맞아도 이름 검증은 실패다. 연결 오류를 없애려고 검증을 끄면 진짜 상대 확인을 버릴 수 있다. 올바른 이름·인증서·신뢰 경로를 맞춘다.

헷갈리는 지점

인증서가 유효하니 서버의 모든 코드·데이터·사업이 안전하다는 결론은 범위를 넘는다. TLS 종료 프록시 뒤의 전송·로그·저장 보호도 별도 경계다.

직접 확인

HTTPS로 접속한 사용자 17이 사용자 18의 신청서를 수정했다. 통신이 암호화되었으니 정상인가?

참고: IETF · TLS 1.3, RFC8446 (www.rfc-editor.org)

B06. 복구목표: 백업간격·실제복원점·RPO·RTO

연결: 061~070회차 · 06-07 | 본문 85쪽

RPO는 허용할 데이터 시점 손실, RTO는 복구에 허용할 시간 목표다. 예약된 백업 시각과 검증된 복원 가능 시점은 다를 수 있다.

원리와 판단 조건

장애 시각에서 마지막 실제 복원 가능 데이터 시점을 빼 데이터 손실 구간을 구한다. 장애부터 업무 기능이 복원된 시각까지를 복구 시간으로 비교한다. 목표 달성은 실제 복원·거래 확인으로 검증한다.

DB 백업 파일만 있어도 복호화 키·설정·외부 연계·응용 버전이 없으면 업무 복원이 실패할 수 있다. RAID 중복·백업·재해 복구와 접근통제의 역할을 구별한다.

적용·손풀이

백업은 매 정시 예약되지만 11시 백업만 검증 성공, 12시·13시 백업은 실패다. 14:20 장애, 15:10 거래 복구이면 실제 손실은 11:00~14:20의 200분, 복구 시간은 50분이다. RPO 60분은 실패, RTO 60분은 충족한다.

헷갈리는 지점

백업 간격 1시간이라는 설정만 보고 RPO 1시간 달성을 선언하지 않는다. 새벽 백업 파일이 있어도 실제 복원 불가라면 그 시점을 근거로 삼지 않는다.

직접 확인

장애 14:20, 복원 가능 시점 14:05, 업무 복원 15:25이고 RPO 30분·RTO 60분이면?

참고: NIST SP800-34 Rev.1 · Contingency Planning (csrc.nist.gov)

보완 문제 정답·해설

문제를 먼저 풀고 첫 오류를 확인합니다. 풀이를 닫은 뒤 같은 조건을 다시 설명할 수 있으면 다음 회차로 넘어갑니다.

B01. 비밀번호 저장: salt·작업 비용·pepper의 서로 다른 역할

앞부분의 사용자별 분리는 유용하지만 뒤 결론은 틀리다. 공격자는 알려진 salt와 후보123456으로 KDF를 계산해 비교할 수 있다. 충분한 비밀번호 품질·적절한 KDF 비용·유출 대응을 함께 다룬다.

B02. 암호화·MAC·서명: 보호 목적을 조합하기

아니다. B도 같은 키를 알아 유효한 MAC을 생성할 수 있다. A의 서명키와 대응 공개키 검증·키 신뢰가 필요한 서명 증거와 구별한다. 서명도 운영 조건이 없는 절대 부인방지로 확대하지 않는다.

B03. 인가 결정표: 역할·객체·행동·상태를 함께 검사

읽기는 감사자 정책으로 허용하고 승인은 거부한다. 이전 읽기 성공이 승인 권한을 만들지 않는다. 기능·객체·행동별 정책을 서버에 적용하고 감사 근거를 남긴다.

B04. SQL 주입·XSS·CSRF: 같은 입력의 서로 다른 경계

아니다. SQL 파라미터화는 DB 문법 경계를 보호한다. 결과를 HTML 문법으로 해석하는 출력 경계는 별도다. 적절한 출력 인코딩이나 안전한 텍스트 API로 처리한다.

B05. TLS: 인증서 확인과 업무 인가를 구분하기

아니다. TLS가 보호한 것은 전송 채널이며 대상 신청서의 업무 인가는 서버가 별도 검사해야 한다. 권한이 없으면 암호화된 정상 형태의 요청이어도 거부한다.

B06. 복구목표: 백업간격·실제복원점·RPO·RTO

손실 구간 15분으로 RPO 충족, 복구 시간 65분으로 RTO 미충족이다. 두 목표는 독립적으로 판정하며 한쪽 성공으로 다른 쪽도 성공이라 쓰지 않는다.